0113. ○△× 16.2회.산기

다음은 syslog의 로그 수준(level/severity)에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

수준	설명
Emergency	시스템이 전면 중단되는 패닉 상태(panic condition)로 모든 사용자에게 공지가 필요한 상황
(A)	시스템 오류 등 즉각적인 조치가 필요한 상황
(B)	급한 상황은 아니지만 심각한 오류가 발생한 상황
Error	일반적인 에러/오류가 발생한 상황
Warning	경고(주의를 요구하는) 상황
(C)	에러/오류는 아니지만, 의미 있는 이벤트가 발생하여 관리자의 확인이 필요한 상황
Information	정보 메시지
Debug	디버깅용 메시지

정답 및 해설

정답 (A) Alert (B) Critical (C) Notice

0114. ○△× 13.1회.산기

다음의 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

syslog는 기밀성, 무결성, 가용성 등 정보보호 특성을 고려하지 않고 개발되었다. 따라서 UDP를 통해 로그를 전송할 때 공격자가 syslog 메시지를 모니터링하여 중요 정보를 알아낼 수 있다. 이 때문에 RFC 3195(Reliable Delivery for syslog)에서는 다음과 같은 몇 가지 보안 기능을 제공하도록 권고하고 있다.

1) 로그 전송의 신뢰성 보장을 위해 연결 지향 프로토콜인 (A)을/를 이용하도록 권고한다.
2) syslog 메시지 전송 시 기밀성 보장을 위해 syslog 서버와 로그 수집 대상 서버의 IP를 제외한 페이로드(payload)를 보호할 수 있는 (B)을/를 이용하도록 권고한다.

정답 및 해설

BEEP(the Blocks Extensible Exchange Protocol)는 연결 지향적이고, 비동기적인 연결을 위한 응용 프로그램 프로토콜 프레임워크로 내부적으로 인증, 프라이버시, 재전송을 통한 신뢰성 등을 보장하고 있으므로 좀 더 안전하고 신뢰성 있는 syslog 메시지 전달이 가능하다.

정답 (A) TCP (B) BEEP

0115. ○△× 18.2회.산기

분산 시스템 또는 프로세스의 로그(메시지)를 중앙 수집기로 보내 로깅과 분석을 수행하기 위한 UDP 기반의 인터넷 표준 프로토콜을 무엇이라 하는가?

정답 및 해설

정답 syslog 프로토콜

0116. ○△×

다음 보기의 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

리눅스 서버에서 생성된 로그파일은 시간이 오래 지나면, 그 파일의 크기가 계속 커지게 되어 파일 시스템의 제한을 벗어나게 된다. 따라서 이를 효율적으로 관리하기 위하여 (A)라는 응용 프로그램을 사용한다. (A)은/는 시스템에 있는 모든 로그파일을 관리할 수 있으며 이러한 로그파일을 적당한 크기로 보관하고, 삭제하고, 압축하고, 메일로 보내주는 등의 작업을 할 수 있게 한다. (A)는 (B) 데몬을 이용하여 주기적으로 작업을 수행할 수 있다.

정답 및 해설

logrotate의 주요 기능은 다음과 같다.

- 로그파일을 순환시킨다.
- 로그파일을 압축해서 보관한다.
- 지정한 용량만큼 찼을 때 다른 파일로 순환시킨다.
- 작업 시 에러가 발생했을 때 지정한 주소로 메일을 보낸다.

정답 (A) logrotate (B) cron

0117. ○△× 18.1회.산기

다음 보기의 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

logrotate는 리눅스 시스템의 로그파일을 관리하기 위한 도구로 로그파일의 순환(rotate), 압축(compression) 등의 기능을 제공한다. logrotate의 설정 파일은 (A)이며, logrotate를 적용할 프로세스(데몬 프로세스)의 개별 설정 파일이 위치한 디렉터리는 (B)이다. 주기적으로 logrotate를 실행하기 위해 (C) 프로그램을 이용한다.

정답 및 해설

logrotate는 cron 서비스(프로그램)를 통해 주기적으로 실행된다. logrotate를 설치하면 기본적으로 /etc/cron.daily 디렉터리에 logrotate 스크립트 파일이 생성되어 cron 데몬을 통해 매일 동작하게 된다. 만약 매시간 동작이 필요하다면 /etc/cron.hourly 디렉터리에 logrotate 스크립트 파일을 복사해서 넣으면 된다.

```
root@Fedora11:~                                   root@Fedora11:~
[root@Fedora11 ~]# ls /etc/cron.daily
0logwatch  logrotate        mlocate.cron  readahead.cron  rpm        tripwire-check
cups       makewhatis.cron  prelink       rkhunter        tmpwatch
[root@Fedora11 ~]# cat /etc/cron.daily/logrotate
#!/bin/sh

/usr/sbin/logrotate /etc/logrotate.conf >/dev/null 2>&1
EXITVALUE=$?
if [ $EXITVALUE != 0 ]; then
    /usr/bin/logger -t logrotate "ALERT exited abnormally with [$EXITVALUE]"
fi
exit 0
[root@Fedora11 ~]#
```

정답 (A) logrotate.conf (B) /etc/logrotate.d (C) cron

0118. ○△× 22.2회.산기

다음 보기의 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

서버에서 생성되는 로그파일은 시간이 지남에 따라 발생하는 로그가 지속해서 쌓여 파일시스템의 제한을 초과하는 문제가 발생할 수 있다. 이를 효율적으로 관리하기 위해 리눅스 시스템에서는 logrotate 서비스(프로그램)를 제공하고 있다. logrotate의 기본 설정 파일은 (A)이며, logrotate를 적용할 개별 프로세스의 설정 파일은 (B) 디렉터리에 있다. 또한 주기적으로 logrotate를 실행하기 위해 (C) 서비스(프로그램)를 이용한다.

정답 및 해설

정답 (A) logrotate.conf (B) /etc/logrotate.d (C) cron

0119. ○△× 16.2회.산기

리눅스 시스템에서 웹서버의 로그를 logrotate를 이용하여 보관하려고 한다. 다음 설명에 적절한 옵션을 쓰시오.

(A) : 1주일 단위로 로테이션(순환)한다.

(B) : 4개의 순환 파일을 사용한다.

(C) : 로그파일을 압축하여 보관한다.

```
/etc/logrotate.d# cat httpd
/var/log/httpd/*log{
    (    A    )
    (    B    )
    (    C    )
    missingok
    notifempty
    sharedscripts
    postrotate
        /bin/kill -HUP `cat /var/run/httpd/httpd.pid 2>/dev/null` 2> /dev/null
    endscript
}
```

정답 및 해설

- daily, weekly, monthly, yearly : 매일, 매주, 매월, 매년 단위로 로그파일 순환
- rotate [개수] : 개수만큼 로그 순환 파일을 사용
- compress, nocompress : 로그파일을 압축하여, 압축 없이 보관
- missingok : 로그파일이 없어도 오류를 발생시키지 않는다.
- notifempty : 'not if empty'의 의미로 로그파일이 비어있는 경우 순환하지 않음
- sharedscripts : 로그파일이 여러 개 있어도 스크립트를 공유하여 prerotate, postrotate 스크립트를 한 번만 실행
- postrotate/endscript : 순환 후 스크립트 파일 실행

정답 (A) weekly (B) rotate 4 (C) compress

0120. ○△× 18.2회.기사

다음은 리눅스 시스템에서 로그파일을 관리하기 위한 logrotate 설정 파일(/etc/logrotate.conf)에 대한 설명이다. 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

(A) : 주 단위로 로그파일을 순환한다.
(size 1M) : 로그파일이 1MB가 되면 순환한다.
(B) : 오래된 로그부터 순환한 후 새롭게 로그파일을 생성한다.
(C) : 로그를 압축하여 저장한다.

정답 및 해설

정답 (A) weekly (B) create (C) compress

0121. ○△× 20.1회.산기

리눅스 시스템 관리자(root)는 cron 프로그램을 이용하여 보기와 같은 작업을 수행하려고 한다. 보기에 나와 있는 crontab 설정 파일의 빈칸 (A), (B), (C)를 완성하시오.

보기

매일 새벽 3시에 /home 디렉터리에 있는 모든 파일을 백업하기 위한 /root/backup.sh 셸 스크립트를 실행시킨다.
crontab 설정 〉 1 3 (A) (B) * (C)

정답 및 해설

- 관리자(root) 계정의 crontab 파일(/var/spool/cron/root)에 설정된 작업의 의미를 살펴보면 다음과 같다.

```
[root@Fedora11 ~]# whoami
root
[root@Fedora11 ~]# crontab -l
1       3       *       *       *       /root/backup.sh
```

- crontab -l 명령을 이용하여 현재 사용자(root)가 등록한 작업 내역 확인

1	3	*	*	*	/root/backup.sh
① 분	② 시	③ 일	④ 월	⑤ 요일	⑥ 작업

필드	의미
① 분	분(minute)은 0-59까지의 숫자로 표시
② 시	시(hour)는 0-23까지의 숫자로 표시
③ 일	일(day of month)은 1-31까지의 숫자로 표시
④ 월	월(month)은 1-12까지의 숫자로 표시
⑤ 요일	▪ 요일(day of week)은 0-6까지의 숫자로 표시(0:일요일, 1:월요일 ~ 6:토요일) ▪ 단, 일요일은 0 또는 7로 표시
⑥ 작업	실행할 작업으로 절대 경로로 표시하고 필요시 옵션과 인수를 함께 표시

- 기출 문제의 crontab 설정은 3시 1분에 동작하는 설정이다. 만약 정확히 3시 0분에 동작하도록 설정한다면 분 필드를 0으로 설정해야 한다.

정답 (A) * (B) * (C) /root/backup.sh

0122. ○△× 15.2회.기사

일반적인 보안 취약점 점검 가이드라인에 의하면, Unix 시스템에서 root 사용자의 원격 접속은 보안상 문제가 될 수 있으므로 root로 원격 로그인이 가능하지 않도록 설정하는 것을 권고하고 있다. 다음은 root 계정의 원격 로그인을 차단하기 위해 Unix 운영체제별로 로그인 설정 파일을 수정하는 화면이다. 다음 (A), (B), (C)에 들어갈 파일이름을 쓰시오.

OS별 점검 파일 위치 및 점검방법	

Solaris(SunOS)	#cat /etc/default/(A)
	CONSOLE=/dev/console

AIX	#cat /etc/security/(B)
	rlogin = false

Linux	#cat /etc/(C) CONSOLE tty1 #pts/1

정답 및 해설

OS별 root 계정에 대한 원격 접속 제한 설정은 다음과 같다.

1) Solaris(SunOS) 보안 설정
- /etc/default/login 파일의 CONSOLE 라인을 통해 root의 원격 접속을 제한할 수 있다. CONSOLE 라인에 #을 붙이면(주석 처리) 외부에서 root 계정으로 접속할 수 있고 #을 붙이지 않으면 콘솔에서만 접근할 수 있다.

2) AIX 보안 설정
- /etc/security/user 파일의 rlogin 설정을 true로 하면 원격에서 root 계정으로 접속할 수 있고 false로 하면 원격에서 접근할 수 없다.

3) Linux 보안 설정
- 리눅스는 로그인 서비스에 pam_securetty.so PAM 모듈을 추가한 후 /etc/securetty 파일에 'pts/~' 터미널을 모두 제거(또는 주석 처리)한다.
- pts(pseudo-terminal, 가상터미널)는 Telnet, SSH 등 원격으로 접속하는 가상터미널을 의미하며 이를 제거 또는 주석 처리하면 root 계정의 pts를 통한 접속을 허용하지 않는다.

정답 (A) login (B) user (C) securetty

0123. ○ △ × 20.2회.산기

다음 보기는 리눅스 시스템의 보안 설정에 관한 내용이다. 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

다음 설정은 리눅스 시스템에 있는 (A)의 (B)을/를 제한하기 위한 설정이다.

■ 설정

1. /etc/securetty 파일에 있는 pts/0, pts/1, pts/2 등 pts 관련 터미널 설정을 모두 제거 또는 주석 처리한다.
2. /etc/pam.d/login 설정 파일을 수정한다.
   (수정 전) #auth required /lib/security/pam_securetty.so
   (수정 후) auth required /lib/security/pam_securetty.so

정답 및 해설

- 루트(root) 계정은 시스템을 관리하는 중요 계정으로 직접 로그인이 가능하면 불법적인 침입자의 목표가 될 수 있으므로 루트 계정의 원격 접속을 금지하도록 보안 설정을 한다.
- 터미널 접속 시 /etc/securetty 파일에 등록된 터미널이 아니면 루트(root)의 접속을 허용하지 않도록 PAM 설정을 할 수 있다. /etc/securetty 파일에 pts(pseudo-terminal) 가상터미널을 모두 제거 또는 주석 처리함으로써 Telnet 등 터미널을 통한 원격 접속을 제한한다.

정답 (A) 루트(root) 계정 (B) 원격 접속

0124. ○ △ × 18.1회.산기

알기사 사이트 보안 관리자는 리눅스 시스템의 로그파일을 점검하던 중 원격에서 root 계정으로 터미널로 접속한 로그를 발견하였다. root 계정으로 원격 로그인이 가능할 경우 보안상 문제가 발생할 수 있으므로 관리자는 root 계정의 원격 접속을 차단하려고 한다. 다음 각각의 질문에 서술하시오.

1) telnet 접속 시 root 계정 접근 제한을 위한 설정 파일은 무엇인가? (pam 모듈 이용)

2) ssh 접속 시 root 계정 접근 제한을 위한 설정 파일은 무엇인가?

3) 실패한 로그인 시도에 대한 기록을 담고 있는 파일은 무엇인가?

4) 최근 성공한 로그인 기록을 확인하기 위한 last 명령어의 출력 필드를 4가지 이상 쓰시오.

정답 및 해설

1) securetty
   - telnet의 root 접속을 차단하기 위해서는 pam_securetty.so pam 모듈에서 참조하는 securetty 파일에서 가상터미널을 의미하는 pts/0 ~ pts/x 설정을 제거하거나 주석 처리한다.

2) sshd_config
   - ssh의 root 접속을 차단하기 위해서는 sshd 설정 파일인 sshd_config 파일의 PermitRootLogin 옵션을 no로 설정한다.

3) btmp

4) last 명령의 출력 필드에는 접속계정, 터미널 타입, 접속주소, 로그인 시간, 로그아웃 시간 등이 있다.

0125. ○ △ × 23.1회.산기

레드햇(Red Hat) 리눅스 시스템에서 다음과 같은 비밀번호 복잡성 설정을 적용하고자 한다. PAM 모듈 또는 설정 파일에서 사용하는 변수명 및 값을 쓰시오.

1) 영문 대문자 최소 1자 이상 설정

2) 특수문자 최소 1자 이상 설정

3) 비밀번호 최소 10자 이상 설정

정답 및 해설

- 레드햇(Red hat) 리눅스 시스템에서 비밀번호 복잡성 설정 시 사용하는 변수명 및 값은 다음과 같다.

권장값	기능	설명
lcredit=-1	(lower case) 최소 소문자 요구	최소 1자 이상의 소문자 요구
ucredit=-1	(upper case) 최소 대문자 요구	최소 1자 이상의 대문자 요구
dcredit=-1	(digit) 최소 숫자 요구	최소 1자 이상의 숫자 요구
ocredit=-1	(other character) 최소 특수문자 요구	최소 1자 이상의 특수문자 요구
minlen=8	최소 패스워드 길이 요구	최소 8자리 이상 요구
retry=N	패스워드 변경(설정) 실패 ,횟수 제한	패스워드 변경(설정) 실패 시 재시도 횟수를 N회로 제한
difok=N	기존 패스워드와 비교	새 비밀번호가 이전 비밀번호와 달라야 하는 문자 수(N)

- /etc/pam.d/system-auth 설정 예 : 오래된 레드햇 리눅스 버전 설정 방식 예(버전: RHEL 5)

```
[root@Fedora11 ~]# vi /etc/pam.d/system-auth

# pam_cracklib.so : 패스워드 크래킹 대응을 위해 패스워드 설정시 강도(복잡성)를 검사하는 pam 모듈
# retry=3    : 패스워드 변경(설정) 실패 시 재시도 횟수 3회로 제한
# minlen=8   : 최소 8자리 이상의 문자
# lcredit=-1 : lower case, 최소 1자 이상의 소문자 포함
# ucredit=-1 : upper case, 최소 1자 이상의 대문자 포함
# dcredit=-1 : digit, 최소 1자 이상의 숫자 포함
# ocredit=-1 : other character, 최소 1자 이상의 특수 문자 포함
# difok=5    : 이전 패스워드와 최소 5자 이상 다르게 설정
#              (0은 검사 안함, 단 이전과 동일한 패스워드 사용 불가)

password    requisite     pam_cracklib.so try_first_pass retry=3 minlen=8 lcredit=-1 ucredit=-1
dcredit=-1 ocredit=-1 difok=5
```

- /etc/security/pwquality.conf 설정 예 : 최근 레드햇 리눅스 버전 설정 방식 예(버전: RHEL 7)

```
[root@CentOS9S /root]# vi /etc/security/pwquality.conf

password    requisite     pam_cracklib.so try_first_pass retry=3 minlen=8 lcredit=-1 ucredit=-1
dcredit=-1 ocredit=-1 difok=5
```

정답 (1) ucredit=-1 (B) ocredit=-1 (C) minlen=10

0126. ○△× 25.2회.산기

레드햇(Red Hat) 리눅스 시스템에서 다음과 같은 비밀번호 복잡성 설정을 적용하고자 한다. 빈칸( )에 적절한 옵션을 쓰시오.

보기

```
# vi /etc/security/pwquality.conf
password requisite pam_cracklib.so try_first_pass ( A ) ( B ) ( C ) ( D )
```

A : 패스워드 설정(변경) 실패 시 재시도 횟수를 3회로 제한

B : 패스워드 최소 길이를 8자로 설정

C : 특수문자를 최소 1자 이상 설정

D : 이전 패스워드와 최소 5자 이상 다르게 설정

정답 및 해설

정답 (A) retry=3 (B) minlen=8 (C) ocredit=-1 (D) difok=5

0127. ○△× 21.2회.산기

다음 보기에서 설명하는 용어를 쓰시오.

보기

윈도우 운영체제에서 파일 공유, 프린터 공유, 원격 윈도우 서비스 액세스 등에 사용되는 전송 프로토콜로 2017년 4월 150여 개국 약 30만대의 PC를 감염시킨 워너크라이(또는 워너크립터) 랜섬웨어(WannaCry/WannaCryptor Ransomware)가 해당 프로토콜의 취약점을 이용하여 전파되었다.

정답 및 해설

SMB(Server Message Block, 서버 메시지 블록) 프로토콜은 주로 윈도우 운영체제 환경에서 사용되는 파일(폴더/디렉터리), 프린터, 직렬 포트 등에 대한 공유 프로토콜로 유닉스/리눅스 운영체제에서는 삼바(SAMBA) 소프트웨어를 설치하면 SMB를 이용한 유닉스/리눅스와 윈도우 컴퓨터 간 공유가 가능하다.

- 초기 SMB는 NetBIOS(NetBEUI) API에서 동작했으며 TCP 139번 포트를 사용
- 윈도우 2000 이후 SMB 기능을 확장하여 CIFS(Common Internet File System, 공통 인터넷 파일시스템)라는 이름으로 변경, NetBIOS에 의존하지 않고 TCP 445번 포트를 사용한 직접 통신 지원
- 네트워크에 연결된 서로 다른 운영체제 간에도 자원을 쉽게 공유할 수 있는 장점(호환성)으로 널리 사용되고 있지만 동시에 여러 보안 취약점으로 인해 컨피커 웜 바이러스, 워너크라이(워너 크립터) 랜섬웨어, 워너마인(WannaMine) 암호화폐 채굴 악성코드 등에 악용되어 왔다.

정답 SMB(Server Message Block)

0128. ○△× 16.1회.산기 22.4회.산기

다음 빈칸( )에 적절한 용어를 쓰시오.

알기사 사이트 관리자는 관리 서버의 NetBIOS 및 CIFS(SMB) 서비스 취약점 스캔 공격이 외부에서 지속해서 발생하는 것을 확인하였다. 외부에 해당 서비스를 오픈할 필요가 없어 이를 방화벽에서 차단하려고 한다. NetBIOS 및 CIFS(SMB)를 차단하기 위한 포트 번호를 쓰시오.

- NetBIOS 포트 번호 : TCP/UDP (A) ~ (B)
- SMB/CIFS 포트 번호 : TCP/UDP (C)

정답 및 해설

NetBIOS(Network Basic Input/Output System)는 LAN(근거리 통신망) 상에 있는 호스트 간에 서로 통신할 수 있도록 해주는 IBM PC를 위한 네트워크 인터페이스 체계로 이름 해석, 세션, 데이터그램의 세 가지 서비스를 제공하고 있다. NetBIOS 기반의 SMB/CIFS 프로토콜을 이용하여 파일, 디렉터리, 프린터 등의 장치를 공유하는 목적으로 주로 사용된다.

프로토콜	포트번호	서비스
TCP	135	▪ RPC Endpoint Mapper ▪ 애플리케이션에서 로컬 또는 원격 프로세스 호출 서비스(분산 서비스)
UDP	137	▪ NetBIOS 이름 해석 서비스 ▪ 호스트의 NetBIOS 이름을 IP 주소로 변환해 주는 서비스
UDP	138	▪ NetBIOS 데이터그램 서비스 ▪ 연결 설정 없이 브로드캐스트 또는 유니캐스트 방식으로 데이터를 전송하는 서비스
TCP	139	▪ NetBIOS 세션 서비스 ▪ 연결 기반 세션을 생성하고 데이터를 전송하는 서비스 ▪ NetBIOS 기반의 SMB/CIFS 서비스(파일, 디렉터리, 프린터 등의 장치 공유 서비스)
TCP/UDP	445	▪ Direct Host(SMB/CIFS over TCP/IP) ▪ TCP/IP 기반의 SMB 서비스

정답 (A) 135 (B) 139 (C) 445

02. 시스템 보안 서술형

0129. ○△× 25.1회.기사

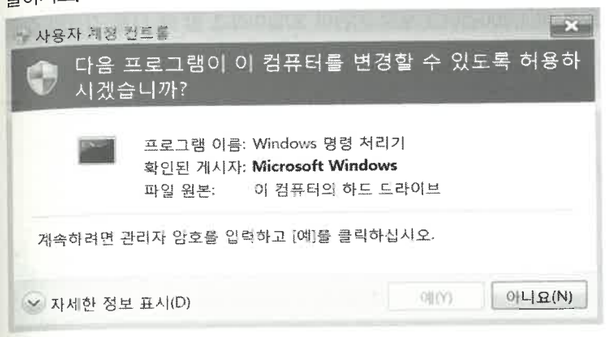
운영체제(OS)에서 제공하는 셸(Shell)의 정의와 기능 2가지를 서술하시오.

정답 및 해설

1) (정의) 사용자와 운영체제(커널) 사이에서 명령어를 해석하는 대화형 사용자 인터페이스
2) (기능) 다음 중 2가지 선택
- 자체 내장 명령어 제공
- 입력 · 출력 · 오류 방향을 재지정할 수 있는 리다이렉션(Redirection) 기능 제공
- 명령어(프로세스) 간 통신을 위한 파이프라인(Pipeline) 기능 제공
- 와일드카드(wildcard) 기능 제공
- 조건부/무조건부 명령열(Sequence) 작성 기능 제공 : 한 번에 여러 명령어를 조건에 따라(또는 조건 없이) 순서대로 실행하는 기능
- 서브셸(Subshell) 생성 기능 제공
- 백그라운드 프로세스(Background process) 처리 기능 제공
- 셸 스크립트(Shell script) 작성 기능 제공

0130. ○△× 24.2회.기사

윈도우 운영체제에서 작업자가 어떤 작업을 수행하던 중에 아래와 같은 사용자 계정 컨트롤(UAC) 팝업이 실행되었다. 사용자는 무엇을 하려고 했으며 팝업에 '예(Y)' 버튼이 비활성화된 이유를 서술하시오.



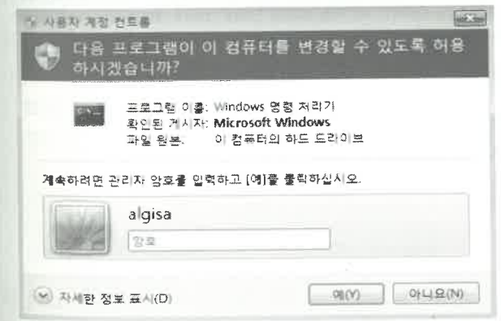
1) 작업자는 무엇을 하려고 했는가?
2) '예(Y)' 버튼이 비활성화된 이유를 서술하시오.

정답 및 해설

윈도우 운영체제의 '사용자 계정 컨트롤(UAC:User Account Control)'은 관리자 권한으로 실행하는 악성코드의 기능을 제한하여 보안을 강화하기 위한 기능으로 권한 없는 프로그램의 자동 실행과 시스템 설정의 임의 변경 등을 방지할 수 있다.

1) 작업자는 윈도우 명령 처리기(cmd.exe)를 관리자 권한으로 실행하려고 한다.
2) 윈도우 관리자 계정(예: Administrator)이 비활성화이거나 존재하지 않는 경우 권한 상승이 불가능하여 사용자 계정 컨트롤 팝업의 '예(Y)' 버튼이 비활성화된다.

(참고) 정상적으로 권한 상승이 가능한 경우 사용자 계정 컨트롤(UAC) 팝업 화면



0131. ○ △ × 25.2회.기사

윈도우 이벤트 로그파일의 크기가 충분하지 않으면 중요 로그가 저장되지 않거나 최대 보존 크기를 초과하면 자동으로 덮어쓰기가 되어 중요 로그의 손실 우려가 있다. 따라서 최대 이벤트 로그 파일의 크기를 적절하게 설정하는 것이 필요하다. 이벤트 로그별 단일 이벤트 크기가 최대 500바이트이고 하루 이벤트 발생량이 약 1,000건이고 보관 기관이 30일이라고 할 때 다음 각각의 질문에 답하시오.

1) 최대 이벤트 로그 크기 계산식을 쓰시오.

2) 최대 이벤트 로그 크기 계산값을 쓰시오.

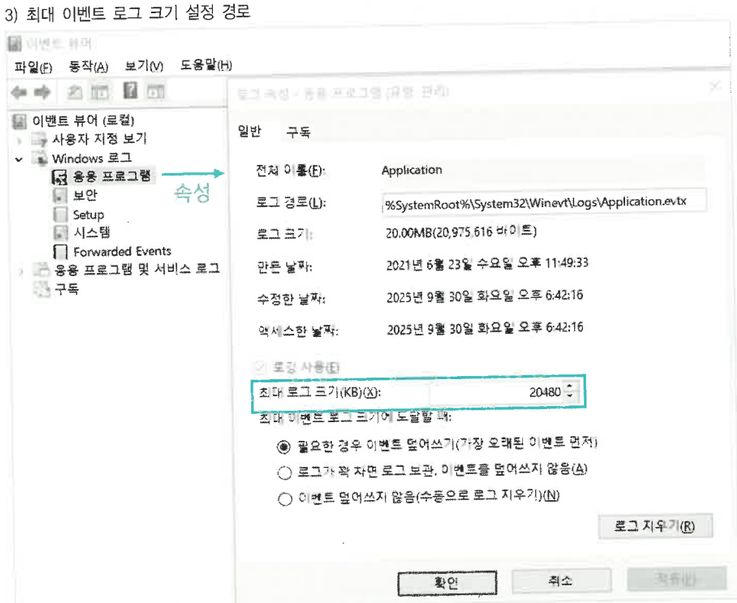
3) 최대 이벤트 로그 크기를 설정하기 위한 경로를 쓰시오.

정답 및 해설

1) 최대 이벤트 로그 크기 계산식
   - 단일 이벤트 최대 크기(500바이트) x 하루 이벤트 발생량(1,000개) x 보관기간(30일)

2) 최대 이벤트 로그 크기 계산값
   - 500 x 1,000 x 30 = 15,000,000바이트

3) 최대 이벤트 로그 크기 설정 경로



- 윈도우 이벤트 뷰어 실행 〉 해당 로그 선택 〉 속성 〉 일반 〉 최대 로그 크기 항목 설정
- (윈도우 이벤트 뷰어 실행 방법) 시작 〉 실행 〉 eventvwr.msc

0132. ○ △ ×

다음은 리눅스 시스템의 /etc/passwd 파일을 출력한 결과이다. 계정 리스트 중에서 비정상적인 것으로 판단되는 계정과 그 이유를 서술하시오.

보기

```
[root@algisa]# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
algisa:x:0:0::/home/salesteam:/bin/bash
generalteam:x:3103:3103::/home/generalteam:/bin/bash
```

정답 및 해설

UID와 GID가 0인 것은 오직 root 계정뿐인데 algisa 계정의 UID/GID가 0으로 변경된 것은 의도적인 권한 상승이 발생했을 가능성이 높다. 리눅스는 계정을 계정명이 아니라 UID/GID로 식별하므로, algisa 계정은 root 계정과 동일한 권한을 갖는다.

0133. ○ △ × 18.2회.산기

알기사 시스템 관리자는 리눅스 시스템 보안 점검 중 /etc/xinetd.conf 파일의 내용이 악의적으로 변경된 것을 확인하였다. xinetd.conf 파일은 관리자(root) 권한을 가진 사용자만 수정이 가능한 파일이다. 다음 각각의 질문에 답하시오.

```
File Edit View Terminal Help
[root@Fedora11 ~]# ls -al /etc/xinetd.conf
-rw-r--r-- 1 root root 1001 2014-03-19 17:49 /etc/xinetd.conf
[root@Fedora11 ~]#
```

1) /etc/passwd 파일을 확인한 결과, 어떤 사용자에 의해 /etc/inetd.conf 파일이 변경된 것으로 의심되는가?

```
*passwd
1 algisa01:x:517:508::/home/algisa01:/bin/bash
2 algisa02:x:517:508::/home/algisa02:/bin/bash
3 algisa03:x:0:508::/home/algisa03:/bin/bash
4 algisa04:x:517:508::/home/algisa04:/bin/bash
5 algisa05:x:517:508::/home/algisa05:/bin/bash
```

2) 의심 사용자 계정의 history 파일을 검색하여 사용한 명령 내역을 확인하려 했지만, 해당 파일이 삭제된 것을 확인하였다. 이 경우 어떤 로그파일을 이용하여 의심 사용자의 명령어 사용 내역을 확인할 수 있는가?

정답 및 해설

1) /etc/inetd.conf 파일은 root만이 수정 권한을 가지고 있으므로 해당 권한을 가진 사용자를 의심할 수 있다. /etc/passwd 파일을 살펴보면 algisa03 계정의 UID가 0(=root)으로 설정된 것으로 볼 때 algisa03 사용자가 xinetd.conf 파일을 변경한 것으로 판단된다.

2) acct/pacct 로그파일
   - acct/pacct 로그파일은 시스템에 로그인한 모든 사용자가 로그아웃할 때까지 입력한 명령어와 터미널의 종류, 프로세스 시작 시간 등을 저장한 로그파일이다.

0134. ○△× 15.2회.산기

다음 지문을 읽고 물음에 답하시오.

보기

리눅스 시스템에서 일반 사용자가 자신의 패스워드를 변경하고자 할 때 (A) 명령어를 사용하고 새로운 패스워드는 (B) 파일에 저장된다. 이때 (A) 명령(실행파일)에 부여된 실행 권한을 (C) 라/이라 한다.

1) 빈칸 (A), (B), (C)에 적절한 용어를 기술하시오.

2) (C)이/가 설정된 프로그램과 설정되지 않은 프로그램을 실행할 때 차이점을 기술하시오.

정답 및 해설

1) A : passwd B : shadow(/etc/shadow) C : SUID(setuid)

2) SUID가 설정된 프로그램은 실행되는 동안 실행파일 소유자의 권한으로 동작한다. 반면, SUID가 설정되지 않은 프로그램은 실행한 사용자 권한으로 동작한다.

0135. ○△× 14.2회.산기

다음은 리눅스 시스템에서 w 명령어를 실행했을 때의 결과이다. 설정상 어떠한 취약점이 있는지 두 가지를 서술하시오.

USER	TTY	FROM	LOGIN	IDLE	JCPU	PCPU	WHAT
root	pts/0	10.0.1.40	Tue 16	9:57m	2.70s	2.67s	nslookup
root	pts/1	10.0.1.80	06:22	0.00s	0.05s	0.04s	python
root	pts/2	10.0.2.72	07:20	21:44	0.01s	0.01s	sh test.sh
root	pts/3	10.0.2.72	06:12	50:59	0.01s	0.00s	-bash
root	pts/4	10.0.1.34	Thu 15	15:50	12.02s	0.00s	-bash

정답 및 해설

1) root 계정은 시스템에서 가장 중요한 계정이므로 원격 접속을 차단하고 su 명령을 통한 제한적 접근만 허용해야 한다. 그러나 출력 결과에서 root 계정의 TTY가 pts로 표시되는 것을 보면, 원격 접속이 허용된 설정 취약점이 있다.

2) 서버 계정에 세션 타임아웃을 설정하여(권장 600초(10분) 이하) 유휴시간(idle time)이 장시간 유지되지 않도록 해야 한다. 하지만 IDLE 컬럼의 결과를 보면 세션 타임아웃 설정이 부적절하여 유휴시간이 장시간 유지되는(예: pts/3 터미널의 경우 50분 59초) 취약점을 보여주고 있다.

0136. ○△× 19.1회.산기 23.4회.산기

다음은 리눅스 시스템의 로그파일에 관한 내용이다. 빈칸( )에 적절한 로그 파일명 또는 로그파일의 내용과 이를 확인하기 위한 명령어를 서술하시오.

1) ( ) : 사용자의 성공한 로그인/로그아웃 정보, 시스템의 Boot/Shutdown 정보에 대한 기록을 담고 있는 로그파일로 last 명령어를 사용하여 내용을 확인할 수 있다.

2) utmp : ( )

3) btmp : ( )

4) lastlog : ( )

정답 및 해설

1) wtmp

2) 현재 로그인한 사용자 정보를 담고 있는 로그파일로 'w', 'who' 등의 명령어를 사용하여 로그 내용을 확인할 수 있다.

3) 실패한 로그인 시도에 대한 기록을 담고 있는 로그파일로 'lastb' 명령어를 사용하여 내용을 확인할 수 있다.

4) 가장 최근에 성공한 로그인 기록을 담고 있는 로그파일로 'lastlog' 명령어를 사용하여 내용을 확인할 수 있다.

0137. ○△× 20.2회.산기

다음은 리눅스 시스템의 로그파일에 관한 내용이다. 각 질문에 답하시오.

1) 아이디, 터미널, 원격 호스트 명 등 동일한 레코드 형식을 사용하는 로그파일로 utmp, wtmp가 있다. 해당 로그파일 내용의 차이점 3가지를 서술하시오.

2) 1)번 로그파일과 동일한 레코드 형식을 사용하는 로그파일로 btmp가 있다. btmp 로그파일의 내용은 무엇이며 이를 확인하기 위한 명령어를 쓰시오.

3) 리눅스 명령어 lastcomm의 기능은 무엇이며 해당 명령어가 참조하는 로그파일을 쓰시오.

정답 및 해설

1) utmp와 wtmp 로그파일 내용의 차이점은 다음과 같다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# w <- utmp 로그 확인 명령
 13:06:56 up 1 day,  4:22,  2 users,  load average: 0.15, 0.04, 0.01
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
root     tty1     :0               09Feb21 27days 31.26s 31.26s /usr/bin/X
root     pts/0    :0.0             13:06    0.00s  0.00s  0.00s w
[root@Fedora11 ~]#
[root@Fedora11 ~]# last <- wtmp 로그 확인 명령
root     pts/0        :0.0             Mon Mar  8 13:06   still logged in
root     pts/1        :0.0             Tue Feb  9 01:38 - 13:06 (27+11:28)
root     pts/0        :0.0             Tue Feb  9 01:19 - 13:05 (27+11:45)
root     tty1         :0               Tue Feb  9 01:19   still logged in
reboot   system boot  2.6.30.10-105.2. Tue Feb  9 01:17         (27+11:49)
```

- utmp는 현재 로그인한 사용자 정보를 가지고 있고 wtmp는 지금까지 로그인한 사용자의 로그인/로그아웃 히스토리 정보를 가지고 있다.
- wtmp는 시스템 부팅(booting) 히스토리 정보를 가지고 있다.
- wmtp는 시스템 셧다운(shutdown) 히스토리 정보를 가지고 있다.

2) btmp는 실패한 로그인 시도에 대한 기록을 담고 있는 로그파일로 'lastb' 명령을 통해 그 내용을 확인할 수 있다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# lastb
kiwi99   pts/3        www.algisa.com   Mon Mar  8 13:24 - 13:24  (00:00)
algisa   pts/3        www.algisa.com   Mon Mar  8 13:11 - 13:11  (00:00)

btmp begins Mon Mar  8 13:10:18 2021
```

3) 'lastcomm' 명령어는 시스템에 로그인한 사용자가 실행한 명령어 관련 정보를 보여주는 명령어로 acct 또는 pacct 로그파일을 참조한다.

0138. ○△×

사내 홈페이지 서버에 보기와 같은 파일이 있다. 각각의 질문에 적절한 명령어를 쓰시오.

보기

```
[root@localhost ~]$ ls -al
-rw-rw-r--   1   algisa   dev   21   2023-02-15 08:09   data_01
-rw-rw-r--   1   algisa   dev   23   2023-02-15 19:21   data_02
```

1) data_01 파일의 소유자를 root로 설정하시오.

2) data_02 파일의 소유그룹을 sec로 설정하시오.

정답 및 해설

1) chown 소유자 파일명 : 해당 파일 소유자를 변경한다. 단 슈퍼 유저(root)만 실행할 수 있다.

2) chgrp 소유그룹 파일명 : 해당 파일에 대한 소유그룹을 변경한다. 단, 슈퍼 유저(root)만 실행할 수 있다.

정답 (A) chown root data_01 (B) chgrp sec data_02

0139. ○△× 24.4회.기사

다음 보기는 유닉스/리눅스 시스템의 파일 접근권한 설정 예이다. 접근권한의 의미를 서술하시오.

보기

(접근권한) -rwxr-x--x

정답 및 해설

파일에 대해 소유자(Owner)는 읽기(r), 쓰기(w), 실행(x)이 가능하고 소유그룹(Group)은 읽기(r), 실행(x)만 가능하고 소유자와 소유그룹을 제외한 모든 사용자(Others)는 실행(x)만 가능하다.

0140. ○△×

사내 백업 서버에 로그인하면 아래와 같은 파일이 있다. 각각의 질문에 적절한 명령어를 쓰시오.

보기

```
[algisa@localhost ~]$ ls -al
-rw-r--r--  1  algisa  dev  21  2022-12-23 08:09  .bash_profile
-rw-rw-r--  1  algisa  dev  23  2023-01-05 19:21  data_01
-rw-rw-r--  1  algisa  dev  41  2023-01-06 05:10  data_02
-rw-rw-r--  1  algisa  dev  15  2023-01-06 05:11  data_03
-rw-----r--  1  algisa  dev  15  2023-01-06 05:12  a.out
```

1) a.out 파일의 소유자는 읽기(r), 쓰기(w), 실행(x) 권한을 부여하고 소유그룹과 기타 사용자는 읽기(r), 실행(x)만 가능하도록 권한을 설정하시오.

2) data_03 파일의 소유그룹 사용자에게 읽기(r), 쓰기(w) 권한을 추가하시오.

정답 및 해설

1) chmod 755 a.out

2) chmod g+rw data_03

- (예) chmod go-w a.out : a.out의 소유그룹(g)과 기타 사용자(o)에 쓰기(w) 권한 제거(-)
- (예) chmod a=rw a.out: a.out의 모든 사용자(a)에 읽기(r)/쓰기(w) 권한 설정(=)
- (예) chmod g+x,o-x a.out: a.out의 소유그룹(g)에 실행(x) 권한을 추가(+)하고 기타 사용자(o)의 실행(x) 권한 제거(-)

0141. ○△× 13.1회.기사 22.1회.기사

다음은 리눅스 시스템의 파일 접근권한 정보이다. setuid, setgid, sticky bit에 대해 아래 파일 및 디렉터리에 관하여 소유자(소유그룹)와 접근권한 관계로 각각 설명하시오.(단, 세 번째 /tmp 디렉터리 내의 파일은 root가 아닌 사용자 권한으로 설명하시오)

접근권한	소유자	소유그룹	파일명
-r-sr-xr-x	root	sys	/usr/bin/passwd
-r-xr-sr-x	root	mail	/usr/bin/mail
drwxrwxrwt	sys	sys	/tmp

정답 및 해설

1) -r-sr-xr-x root sys /usr/bin/passwd

- 첫 번째 행을 보면, user 접근권한의 execute 항목이 s로 설정된 것을 볼 수 있다. 이는 passwd 실행파일에 setuid(SUID)가 설정되어 있음을 의미한다. setuid가 설정되면 해당 프로세스가 실행 중인 동안에 실행시킨 사용자의 권한이 아니라 실행파일 소유자(euid가 실행파일 소유자 id로 설정)의 접근권한으로 동작하게 된다. 따라서 passwd 실행파일이 실행 중인 동안에는 소유자인 root 권한으로 자원에 접근하게 된다.

2) -r-xr-sr-x root mail /usr/bin/mail

- 두 번째 행을 보면, group 접근권한의 execute 항목이 s로 설정된 것을 볼 수 있다. 이는 mail 실행파일에 setgid(SGID)가 설정되어 있음을 의미한다. setgid가 설정되면 해당 프로세스가 실행 중인 동안에 실행시킨 사용자의 기본그룹 권한이 아니라 실행파일 소유그룹(egid가 실행파일 소유그룹 id로 설정)의 접근권한으로 동작하게 된다. 따라서 mail 실행파일이 실행 중인 동안에는 소유그룹인 mail 권한으로 자원에 접근하게 된다.

3) drwxrwxrwt sys sys /tmp

- 세 번째 행을 보면, others 접근권한의 execute 항목이 t로 설정된 것을 볼 수 있다. 이는 tmp 디렉터리에 sticky bit가 설정되어 있음을 의미한다. sticky bit가 설정된 디렉터리는 모든 사용자가 파일 생성은 가능하지만, 삭제 및 이름 변경은 파일 소유자와 root만 가능하다. 일반적으로 모든 사용자가 공유하는 공유 디렉터리는 sticky bit를 설정한다.

0142. ○△× 14.2회.산기

유닉스/리눅스 파일시스템에서 파일의 MAC Time을 확인하여 공격자의 파일 위변조 여부를 파악할 수 있다. MAC Time으로 확인할 수 있는 3가지 정보를 서술하시오.

정답 및 해설

1) mtime(Last Modify Time) : 파일의 내용이 마지막으로 수정된 시간

2) atime(Last Access Time) : 파일에 마지막으로 접근한 시간

3) ctime(Last Change Time) : 파일의 속성 정보(소유자, 접근권한 등)가 마지막으로 변경된 시간

0143. ○△× 15.1회.산기

침해사고 발생 시, 피해 시스템의 특정 로그에 대한 무결성을 확인하기 위해 타임라인 분석을 수행한다. 리눅스 시스템의 파일시스템 타임라인에서 제공하는 시간 속성을 모두 기술하고 각 속성을 간략히 설명하시오.

정답 및 해설

1) mtime(Last Modify Time) : 파일의 내용이 마지막으로 수정된 시간
2) atime(Last Access Time) : 파일에 마지막으로 접근한 시간
3) ctime(Last Change Time) : 파일의 속성 정보(소유자, 접근권한 등)가 마지막으로 변경된 시간

0144. ○△× 19.2회.기사

다음 보기는 리눅스 시스템의 사용자 계정에 대한 인증 관련 PAM(Pluggable Authentication Module) 모듈 설정이다. 각각의 옵션이 의미하는 바를 서술하시오.

보기

```
#cat /etc/pam.d/system-auth
auth required /lib/security/pam_tally.so deny=5 unlock_time=120 no_magic_root
account required /lib/security/pam_tally.so no_magic_root reset
```

1) deny=5
2) unlock_time=120
3) no_magic_root
4) reset

정답 및 해설

1) 5회 입력 실패 시 패스워드 잠금
2) 계정 잠긴 후 마지막 계정 실패 시간부터 120초가 지나면 자동 계정 잠금 해제
3) root 계정은 패스워드 잠금 설정을 적용하지 않음
4) 접속 시도 성공 시 실패 횟수 초기화

0145. ○△×

주요 메모리 해킹기법 중 하나인 버퍼 오버플로우의 예방책을 서술하시오.

정답 및 해설

최근에는 지속적인 위협성 강조와 패치 등으로 버퍼 오버플로우의 취약점이 많이 줄었지만, 대표적인 예방책들은 다음과 같다.

1) 스택가드 : 메모리상에서 프로그램의 복귀주소와 변수 사이에 특정 값(Canary Word)을 저장해 두었다가 그 값이 변경되었을 경우를 오버플로우로 가정하여 프로그램 실행을 중단하는 것을 말한다. '카나리 단어 기법'이라고도 한다.
2) 스택쉴드 : 함수 시작 시에 리턴 주소를 Global RET라는 특수 스택에 저장해 두었다가 함수 종료 시 저장된 값과 스택의 RET 값을 비교해 다를 경우 프로그램을 종료한다.
3) ASLR (Address Space Layout Randomization) : 메모리 공격을 방어하기 위해 주소 공간 배치를 난수화하는 기법으로 실행 시마다 메모리 주소를 변경시켜 악성코드에 의한 특정주소 호출을 방지한다.
4) 프로그램 개발 시 버퍼 오버플로우에 취약하지 않은 함수를 사용하거나 입력값에 대한 적절한 크기 검증을 통해 버퍼 오버플로우가 발생하지 않도록 한다.

0146. ○△× 17.2회.기사

다음은 버퍼 오버플로우 대응 기술에 대한 설명이다. 각 질문에 답하시오.

1) 카나리 단어(Canary Word) 기법의 동작 방식을 간단히 설명하시오.
2) 카나리 단어(Canary Word) 기법의 공격 차단 원리를 설명하시오.
3) ASLR(Address Space Layout Randomization) 기법의 동작 방식을 간단히 설명하시오.
4) ASLR(Address Space Layout Randomization) 기법의 공격 차단 원리를 설명하시오.

정답 및 해설

1) 카나리 단어(Canary Word) 기법은 메모리상에서 프로그램의 복귀주소(Return Address)와 변수 사이에 특정 값(Canary Word)을 저장해 두는 기법을 말한다('스택 가드 기법'이라고도 함).
2) 버퍼 오버플로우 발생 시 특정 값(Canary Word)의 변조가 발생하므로 이를 탐지하여 차단한다.
3) ASLR(Address Space Layout Randomization) 기법은 메모리 공격을 방어하기 위해 주소 공간 배치를 난수화하는 기법을 말한다.
4) 실행 시마다 메모리 주소를 변경시켜 버퍼 오버플로우를 통한 특정주소 호출을 차단한다.

0147. ○△×

다음 리눅스 명령의 기능과 그 이유를 서술하시오.

보기

echo 2 〉 /proc/sys/kernel/randomize_va_space

정답 및 해설

리눅스 커널에서 ASLR(Address Space Layout Randomization)를 설정하는 것으로 버퍼 오버플로우의 예방책 중 하나이다. '주소 공간 배치 난수화(ASLR)'는 프로그램 실행 시마다 스택, 힙, 라이브러리 등의 배치를 랜덤하게 하는 방식으로 매번 다른 주소에서 실행되므로 버퍼 오버플로우 공격에 대비할 수 있다.

- randomize_va_space 커널 파라미터를 0으로 설정하면 사용하지 않는다는 의미이고, 1로 설정하면 힙 이외는 모두 랜덤하게 설정한다는 의미이고, 2로 설정하면 모두 랜덤하게 설정한다는 의미이다.

0148 ~ 0150. ○△×

다음 소스코드와 연관된 아래의 문제에 답하시오.

victim.c

```
1 #include <stdio.h>
2 #include <stdlib.h>
3 #include <unistd.h>
4 #include <fcntl.h>
5 #include <sys/stat.h>
6 #include <sys/types.h>
7
8 void main(int argc, char **argv){
9     int fd;
10    char write_text[]="# Top Secret Information !!! #\n";
11    char *tmp="/tmp/race.tmp";
12
13    fd=open(tmp,O_CREAT|O_RDWR|O_TRUNC);
14    write(fd,write_text,strlen(write_text));
15    close(fd);
16    remove(tmp);
17 }
```

0148. ○△×

아래는 위 소스코드를 공격하기 위한 첫 번째 과정이다. 어떤 명령인지 간단히 서술하시오.

root@localhost:/tmp

File Edit View Terminal Help

```
[root@localhost tmp]# touch hack.txt
[root@localhost tmp]# ls -al /tmp/hack.txt
-rw-r--r-- 1 root root 0 2016-03-15 10:34 /tmp/hack.txt
[root@localhost tmp]#
```

정답 및 해설

'touch' 명령으로 크기가 0인 'hack.txt'라는 파일을 생성하고 'ls' 명령으로 파일 생성을 확인하고 있다.

0149. ○△×

다음은 위의 소스코드를 공격하기 위한 프로그램이다. 동작 방식을 간단히 서술하시오.

attacker.c

```
1 #include <stdio.h>
2 #include <unistd.h>
3
4 void main(int argc, char **argv){
5     int i=0;
6     for(i=0; i<10; i++){
7         printf("run : %d \n",i+1);
8         system("ln -s /tmp/hack.txt /tmp/race.tmp");
9     }
10 }
```

정답 및 해설

미리 생성해둔 /tmp/hack.txt를 원본으로 하는 심볼릭 링크 파일인 /tmp/race.tmp를 만드는 과정을 10번 반복한다.

0150. ○△×

피해 프로그램과 공격 프로그램을 동시에 여러 번 실행한 결과 hack.txt 파일에 아래와 같은 내용이 기록된 것을 확인할 수 있었다. 소스코드와 공격 과정을 참고하여 (1) 공격 명칭과 (2) 대응 방안에 관해 서술하시오.

```
root@localhost:/home/kiwi99/LEC_RACE_COND2
File  Edit  View  Terminal  Tabs  Help
kiwi99@localhost:/home/kiwi99/LEC_RAC...   root@localhost:/home/kiwi99/LEC_RACE...
[root@localhost LEC_RACE_COND2]# cat /tmp/hack.txt
# Top Secret Information !!! #
[root@localhost LEC_RACE_COND2]#
```

정답 및 해설

1. 레이스 컨디션 공격(Race Condition Attack)
   - 공격자는 임시 파일 hack.txt를 미리 만들어두고 피해 프로그램에서 /tmp/race.tmp를 생성하기 전에 동일한 이름으로 심볼릭 링크를 걸게 되면 피해 프로그램은 공격자가 만들어놓은 파일을 사용하게 되어 링크가 걸린 hack.txt에 내용이 기록되고 race.tmp를 지우더라도 hack.txt의 내용은 남게 된다.
   - 피해 프로그램에서 파일을 먼저 생성하면 공격은 실패한다. 누가 먼저 race.tmp 파일을 생성하느냐에 따라 결과가 달라지므로 공격 프로그램은 먼저 생성하는 시점을 확보하기 위해 링크를 10회 반복했다. 여기서 10회는 시점 확보를 위해 많은 반복과 경쟁이 필요함을 상징적으로 표현한 숫자일 뿐 시스템 상황에 따라 다르다.
   - 이러한 공격과정을 살펴볼 때, 경쟁조건을 이용하는 레이스 컨디션 공격(Race Condition Attack)으로 판단된다.
2. 레이스 컨디션 공격 대응 방안
   - 가능하면 임시 파일을 생성하지 않는다. 임시 파일을 만드는 것이 Race Condition의 주요 원인이 된다.
   - 파일 생성 시 이미 동일한 파일이 존재하는 경우 파일 생성 또는 쓰기를 금지한다.
   - 사용하고자 하는 파일에 링크가 걸려있으면 실행을 중단한다.
   - umask를 최하 022 정도로 유지하여 임시로 생성한 파일이 공격자에 의해 악의적으로 삭제되지 않도록 한다.

0151. ○△× 14.2회.산기 23.1회.산기

다음은 각 Unix/Linux OS별로 특정 취약점이 있는지를 점검하는 설정을 보여주고 있다. 어떠한 설정을 점검하는 것인지 간략히 설명하시오.

Solaris(SunOS)	#cat /etc/default/passwd
	MAXWEEKS=12

LINUX	#cat /etc/login.defs PASS_MAX_DAYS 90

AIX	#cat /etc/security/user
	maxage=12

HP-UX	#cat /etc/default/security
	PASSWORD_MAXDAYS=90

정답 및 해설

패스워드의 최대 사용기간을 적절하게 설정하였는지를 점검하기 위한 항목이다. 각 OS별로 패스워드 정책 설정 파일을 점검하여 권장 설정일(최대 90일(12주)) 여부를 확인한다.

- Solaris(SunOS) 및 AIX의 경우 주 단위 설정이 가능하며 권장 최대 12주 이하로 설정한다.
- Linux 및 HP-UX의 경우 일 단위 설정이 가능하며 권장 최대 90일 이하로 설정한다.

0152. ○△× 23.4회.기사

쇼핑몰 운영 서버 취약점 점검 결과 사용자 계정의 패스워드 최소 길이가 부적절한 문제점이 발견되었다. 패스워드 최소 길이를 8자리 이상으로 설정하려고 할 때 Solaris(SunOS), LINUX, AIX, HP-UX 운영체제별로 설정 방법을 서술하시오.

정답 및 해설

운영체제별 패스워드 최소 길이 설정 방법은 다음과 같다.

Solaris (SunOS)	#cat /etc/default/passwd
	PASSLENGTH=8

LINUX	#cat /etc/login.defs PASS_MIN_LEN 8

AIX	#cat /etc/security/user
	minlen=8

HP-UX	#cat /etc/default/security
	MIN_PASSWORD_LENGTH=8

1) Solaris(SunOS) : /etc/default/passwd 설정 파일에 PASSLENGTH를 8로 설정한다.
2) Linux : /etc/login.defs 설정 파일에 PASS_MIN_LEN을 8로 설정한다.
3) AIX : /etc/security/user 설정 파일에 minlen을 8로 설정한다.
4) HP-UX : /etc/default/security 설정 파일에 MIN_PASSWORD_LENGTH를 8로 설정한다.

0153. ○△× 24.2회.기사

리눅스 시스템에서 사용자 패스워드 문자열이 짧은 경우 쉽게 유추가 가능할 수 있으며 다양한 패스워드 크래킹 공격으로 쉽게 크랙될 수 있는 취약점이 있다. 패스워드 최소 길이를 8자 이상으로 설정하기 위해 다음 빈칸( )에 적절한 설정 방법을 쓰시오.

Solaris(SunOS)	#cat /etc/default/passwd
	PASSLENGTH=0

LINUX	#cat /etc/(A) (B) (C)

AIX	#cat /etc/security/user
	minlen=8

HP-UX	#cat /etc/default/security
	MIN_PASSWORD_LENGTH=8

정답 및 해설

정답 (A) login.defs (B) PASS_MIN_LEN (C) 8

0154. ○△× 18.2회.산기

시스템 사용자 계정의 패스워드를 안전하게 관리하기 위해서는 패스워드의 복잡성 설정, 최소 길이 설정, 최대 사용기간 설정 등의 정책이 필요하다. 리눅스 시스템의 패스워드 정책 설정 파일명을 쓰시오.

정답 및 해설

OS별 패스워드 정책 설정 파일은 다음과 같다.

- Solaris(SunOS) : /etc/default/passwd
- LINUX : /etc/login.defs
- AIX : /etc/security/user
- HP-UX : /etc/default/security

정답 login.defs

0155. ○△× 19.1회.기사

다음 보기에서 설명하고 있는 파일의 이름은 무엇인가?

보기

리눅스의 /etc 디렉터리에 있는 패스워드 정책 설정 파일로 패스워드의 최소 길이, 최대 사용기간, 최소 사용기간 등을 설정할 수 있다.

정답 및 해설

리눅스 패스워드 정책 설정 파일인 login.defs 파일의 주요 권장 설정 내용을 살펴보면 다음과 같다.

- PASS_MIN_LEN 8 : 패스워드 최소 길이를 8자 이상으로 설정한다.
- PASS_MAX_DAYS 90 : 패스워드 최대 사용기간을 90일로 설정한다.
- PASS_MIN_DAYS 1 : 패스워드 최소 사용기간을 1일로 설정한다.

정답 login.defs

0156. ○△× 21.1회.산기

유닉스/리눅스 시스템 관리자는 보안 취약점 점검 과정에서 root 계정의 PATH 환경변수 설정이 보기와 같이 되어있는 것을 확인하였다. PATH 설정의 취약점 및 조치 방안에 관해 서술하시오.

보기

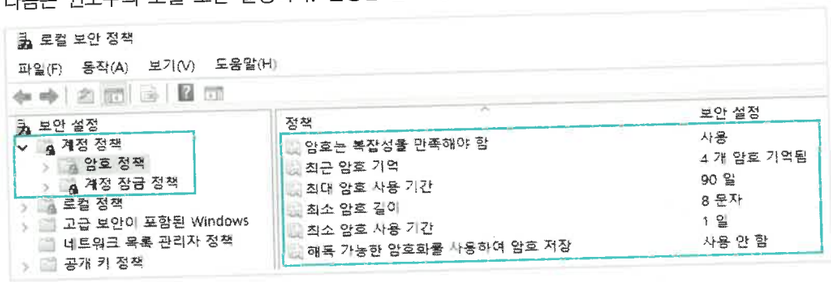
```
# vi /etc/profile
PATH=.:$PATH:/usr/lib/qt-3.3/bin:/usr/kerberos/sbin:/usr/kerberos/bin:/usr/lib/ccache:/usr
/local/sbin:/usr/sbin:/sbin:/usr/local/bin:/usr/bin:/bin:/root/bin
```

정답 및 해설

1) 취약점 : PATH 환경변수에 '.'(현재 디렉터리 지정) 설정이 맨 앞 또는 중간에 있으면 root 계정으로 접속한 관리자가 현재 디렉터리에 불법적으로(악의적으로) 위치한 실행파일(명령)에 의해 의도하지 않은 명령이 실행될 수 있는 취약점이 존재한다.
2) 조치방안 : PATH 환경변수의 '.'(현재 디렉터리 지정) 설정을 맨 뒤로 이동시키거나 불필요한 경우 삭제한다.

0157. ○△×

다음은 윈도우의 로컬 보안 설정이다. 설정된 암호 정책을 간략히 설명하시오.



정답 및 해설

윈도우 암호(패스워드) 보안 정책으로 설정 내용은 다음과 같다.

1) 패스워드 복잡성 설정
- 패스워드 설정 시 영문자(대소)/숫자/특수문자를 모두 포함하여 보안상 안전한 패스워드를 설정한다.
- (권장 설정) : 사용

2) 최근 암호 기억
- 사용자가 현재 또는 최근에 사용했던 패스워드와 동일한 새 패스워드를 만드는 것을 방지하기 위한 설정으로 최근 암호 4개에 대해서는 동일하게 사용할 수 없다.
- (권장 설정) : 4개 이상

3) 최대 암호 사용기간
- 패스워드 사용 만료 기간으로 최대 90일까지 패스워드 사용이 가능하고 그 이후에는 변경해야 한다.
- (권장 설정) : 90일 이하

4) 최소 암호 길이
- 패스워드 최소 길이를 8자 이상으로 설정한다.
- (권장 설정) : 8자 이상

5) 최소 암호 사용기간
- 새롭게 설정한 패스워드를 1일 동안 변경하지 못한다. 최소 암호 기간을 설정하는 이유는 패스워드 변경에 시간 제약이 없다면 '최근 암호 기억'을 무력화하도록 계속 변경하여 이전에 즐겨 사용하던 패스워드를 다시 사용하는 보안상의 문제점이 있기 때문이다.
- (권장 설정) : 0보다 큰 값으로 설정(일반적으로 1일 설정)

6) 해독 가능한 암호화를 사용하여 암호 저장
- 해독 불가능한 암호화 방식을 사용한다.
- (권장 설정) : 사용 안 함

0158. ○△× 23.2회.기사 25.1회.기사

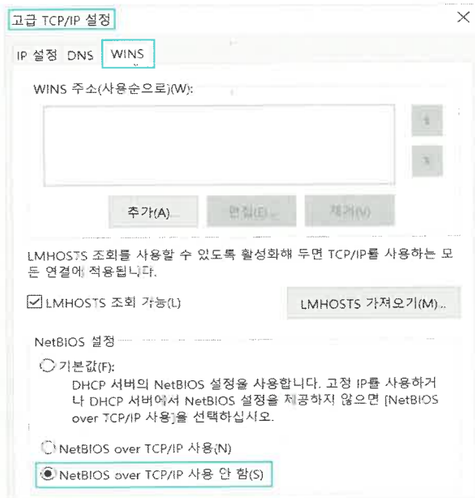
윈도우 시스템에서 사용하는 NetBIOS 바인딩(NetBIOS TCP/IP 바인딩)이 취약한 이유와 보안 설정 방법을 서술하시오.(보안 설정은 ncpa.cpl을 이용하여 설명)

정답 및 해설

NetBIOS(Network Basic Input/Output System)는 LAN(근거리 통신망) 상에 있는 호스트 간에 서로 통신할 수 있도록 해주는 IBM PC를 위한 네트워크 인터페이스 체계로 이름 해석, 세션, 데이터그램의 세 가지 서비스를 제공하고 있다. NetBIOS 기반의 SMB 프로토콜을 이용하여 파일, 디렉터리, 프린터 등의 장치를 공유하는 목적으로 주로 사용된다.

1) NetBIOS 바인딩이 취약한 이유
- 인터넷에 직접 연결된 윈도우 시스템에서 NetBIOS TCP/IP 바인딩이 활성화되어 있으면 인터넷을 통해 외부 공격자가 윈도우 시스템의 네트워크 공유자원에 접근할 수 있는 취약점이 발생한다.

3) 보안 설정 방법
- 네트워크 제어판을 이용하여 NetBIOS와 TCP/IP 간 바인딩을 제거한다. 구체적인 제거 방법은 다음과 같다.
- ncpa.cpl(네트워크 연결 제어판) 실행 〉 네트워크 인터페이스 선택 〉 TCP/IPv4 속성에서 고급 설정 선택 〉 WINS 탭에서 "NetBIOS over TCP/IP 사용 안 함" 선택



03. 시스템 보안 실무형

0159. ○△× 13,2회,산기

리눅스에 등록된 사용자 계정과 패스워드 정보는 /etc/passwd, /etc/shadow 속에 기본적인 내용들이 정의되어 있다. 아래 예시한 각각의 파일 구조를 보고 밑줄 친 부분에 관하여 기술하시오.

보기

/etc/passwd 파일

root : x : 0 : 0 : root : /root : /bin/bash

① ② ③

/etc/shadow 파일

root : 1nL5SgjKF$IvSugCJKDGmQKmopLvq0t/ : 15455 : 0 : 99999 : 7 : : :

④ ⑤ ⑥ ⑦

정답 및 해설

① 사용자 패스워드, x의 의미는 shadow 패스워드를 사용한다는 의미이다.
② 기본그룹 ID
③ 홈 디렉터리
④ 암호화된 패스워드
⑤ 마지막으로 패스워드를 변경한 날(1970년 1월 1일을 기준으로 일수로 표시)
⑥ 패스워드 만료일(패스워드를 마지막으로 변경한 날 이후 일수로 표시)
⑦ 경고 일수(패스워드 만료 전 경고 일수)

0160. ○△× 15,2회,산기

리눅스에 등록된 사용자 계정과 패스워드 정보는 /etc/passwd, /etc/shadow 속에 기본적인 내용들이 정의되어 있다. 아래 예시한 각각의 파일 구조를 보고 밑줄 친 부분에 관하여 기술하시오.

보기

/etc/passwd 파일

root : x : 0 : 0 : root : /root : /bin/bash

① ② ③ ④

/etc/shadow 파일

root : 1nL5SgjKF$IvSugCJKDGmQKmopLvq0t/ : 16188 : 0 : 99999 : 7 : : :

⑤ ⑥ ⑦

정답 및 해설

① 사용자 패스워드, x의 의미는 shadow 패스워드를 사용한다는 의미이다.
② 기본그룹 ID
③ 홈 디렉터리
④ 로그인 셸
⑤ 암호화된 패스워드
⑥ 마지막으로 패스워드를 변경한 날(1970년 1월 1일을 기준으로 일수로 표시)
⑦ 패스워드 만료일(패스워드를 마지막으로 변경한 날 이후 일수로 표시)

0161. ○△× 13,2회,산기

운영 중인 리눅스 홈페이지 서버의 /etc/passwd 파일을 열어보니 기존의 내용이 ①과 ②로 변경되어 있었다. 각각 어떤 의미인지 설명하시오.

보기

변경전)

/etc/passwd 파일

root : x : 0 : 0 : root : /root : /bin/csh

변경후)

/etc/passwd 파일

root : x : 0 : 0 : root : /hack2 : /bin2/hack3

① ②

정답 및 해설

①은 root 계정의 홈 디렉터리 필드로 기존 /root 디렉터리에서 /hack2 디렉터리로 변경되었고 ②는 root 계정의 로그인 셸 필드로 기존 /bin/csh에서 /bin2/hack3로 변경되었다. 따라서 관리자가 root 계정으로 로그인하면 공격자(해커)에 의해 변경된 내용이 적용되어 홈 디렉터리는 /hack2 디렉터리가 되고 로그인 셸은 /bin2/hack3가 된다.

0162. ○△×

리눅스 시스템 관리자는 패스워드를 설정하지 않은 계정을 찾기 위해 vi 편집기로 보기와 같은 파일을 열었다. 다음 질문에 답하시오.

1) 파일명은 무엇인가?
2) 패스워드를 설정하지 않은 계정은 무엇인가?
3) 관리자가 (2)번 계정의 패스워드를 설정하기 위해 사용하는 명령어는 무엇인가?

보기

```
# vi 편집기로 연 파일의 일부
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
algisa::5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
```

정답 및 해설

1) passwd(/etc/passwd) 파일
2) algisa 계정 : 해당 계정의 패스워드 필드인 두 번째 필드가 비어있다.
3) passwd algisa

0163. ○ △ × 19.2회.기사

다음은 리눅스 시스템의 /etc/shadow 파일에 저장된 algisa 계정의 패스워드 정보이다. 다음 각각의 질문에 답하시오.

algisa:6gAWyPqwb$kmjg2WA4E7S2MT/1h~생략~:18290:1:90:7:::

(A) (B) (C)

1) algisa 계정의 두 번째 필드 A, B, C 각 항목의 의미를 쓰시오.

2) 두 번째 필드의 B 항목을 통해 레인보우 테이블(rainbow table) 공격에 효과적으로 대응할 수 있다. 그 원리가 무엇인지 쓰시오.

3) 위 파일과 관련하여 pwunconv 명령어의 용도를 쓰시오.

정답 및 해설

1) 두 번째 필드 각 항목의 의미는 다음과 같다.
- A : 패스워드 암호화에 적용된 일방향 해시 알고리즘 식별 ID
- B : 패스워드 암호화에 적용된 솔트(salt)
- C : 암호화된 패스워드(해시값)

2) 레인보우 테이블 공격을 통해 암호화된 패스워드(해시값)의 평문 패스워드를 알아낸다고 해도 이는 솔트(salt)와 조합된 패스워드 해시값에 대한 평문 패스워드로 실제 패스워드가 아니다. 따라서 크랙된 평문 패스워드로 로그인을 시도하면 패스워드 검증 시 입력한 패스워드에 솔트를 조합한 해시값을 비교하기 때문에 로그인에 실패하게 된다.

3) pwunconv 명령어는 사용자 계정의 패스워드 정책을 shadow 패스워드 정책(shadow 파일에 패스워드 별도 보관)에서 일반 패스워드 정책(passwd 파일 내 계정정보와 함께 보관)으로 변경한다.

리눅스 시스템에서 패스워드 저장 정책을 변경하는 명령어에는 pwconv와 pwunconv 명령어가 있다. 각 명령어의 목적은 다음과 같다.

- pwconv 명령어 : 사용자 계정 패스워드 저장 정책을 shadow 패스워드 정책(shadow 파일에 패스워드 별도 저장)으로 변경하는 명령어
- pwunconv 명령어 : 사용자 계정 패스워드 저장 정책을 shadow 패스워드 정책(shadow 파일에 패스워드 별도 저장)에서 일반 패스워드 정책(passwd 파일 내 계정정보와 함께 보관)으로 변경하는 명령어

```
root@Fedora11:~
[root@Fedora11 ~]# cat /etc/passwd | grep 'algisa:'
algisa:x:519:514::/home/algisa:/bin/bash
[root@Fedora11 ~]#
[root@Fedora11 ~]# cat /etc/shadow | grep 'algisa:'
algisa:$1$Q4jbDpHG$3fCuhTpWNIVrxgGOOJA9S.:18290:1:90:7:::
[root@Fedora11 ~]#
[root@Fedora11 ~]# pwunconv
[root@Fedora11 ~]#
[root@Fedora11 ~]# cat /etc/passwd | grep 'algisa:'
algisa:$1$Q4jbDpHG$3fCuhTpWNIVrxgGOOJA9S.:519:514::/home/algisa:/bin/bash
[root@Fedora11 ~]#
[root@Fedora11 ~]# cat /etc/shadow | grep 'algisa:'
cat: /etc/shadow: No such file or directory
[root@Fedora11 ~]#
```


0164. ○ △ ×

리눅스 시스템에서 관리자는 algisa 사용자에 대해 보기의 설정을 하고자 한다. 아래 작업 내용에 해당하는 명령문(옵션 포함)을 작성하시오.(단, passwd 명령어를 사용하여 작성)

보기

1) algisa 사용자 패스워드 잠금
algisa 사용자의 패스워드에 잠금을 설정하면 algisa 사용자는 서버로 원격 접속(Telnet, FTP 등)을 못하게 된다.

2) algisa 사용자 패스워드 잠금 해제
algisa 사용자에 설정하였던 패스워드 잠금을 해제하면 algisa 사용자는 정상적인 원격 접속을 할 수 있으며 이전에 사용하던 패스워드를 그대로 사용할 수 있다.

정답 및 해설

1) passwd -l algisa (소문자 L 옵션)
- 패스워드 잠금 설정(lock) 명령 : passwd -l 계정명

2) passwd -u algisa
- 패스워드 잠금 해제(unlock) 명령 : passwd -u 계정명

0165. ○ △ × 13.1회.산기

다음 보기는 'ls -l' 명령 실행 후 파일이나 디렉터리의 권한(Permission)을 확인하는 화면이다. ① ~ ⑥의 의미를 예시에서 선택하시오.

보기

예시 : 그룹, 소유주, 소유주 권한, 그룹 권한, 3자 권한, 파일 및 디렉터리 의미

[root@localhost ~]# ls -l

d	rwx	r-x	r-x	5	root	root	59	2012-01-14 18:28	result.dat
①	②	③	④		⑤	⑥			

정답 및 해설

'ls -l' 명령 출력 결과는 다음과 같다.

-rw-r--r--	1	algisa	topspot	9423	Feb	24	15:01	program.c
drwx--x--x	4	algisa	topspot	512	Jul	31	10:31	lib
❶	❷	❸	❹	❺	❻		❼	❽

❶ 파일종류 및 접근권한 ❷ 하드 링크수 ❸ 소유주 ❹ 소유 그룹 ❺ 크기 ❻ 최종 수정일 ❼ 최종 수정시간 ❽ 파일명

정답 ① 파일 및 디렉터리 의미 ② 소유주 권한 ③ 그룹 권한 ④ 3자 권한 ⑤ 소유주 ⑥그룹

0166. ○△× 13.1회.기사

알기사 교육기관 서버 담당자는 서버 점검 중 /etc/apache/conf 내의 파일이 수정된 것을 발견했다. 담당자가 10일 이내에 파일을 수정한 적이 없을 때 무결성을 확인할 수 있는 find 명령을 한 줄로 작성하시오.

정답 및 해설

find 명령어의 옵션 중 시간(time) 관련 옵션은 다음과 같다.

1) 파일 시간 속성에 따라 atime(access time), mtime(modification time), ctime(change time)으로 구분한다.
   - -atime : access time, 파일을 마지막으로 접근한 시간을 지정
   - -mtime : modification time, 파일의 내용이 마지막으로 변경된 시간을 지정
   - -ctime : change time, 파일의 속성이 마지막으로 변경된 시간을 지정
2) -mtime [+-]n : +-가 없으면 정확히 n일, +n이면 n일 초과, -n이면 n일 미만인 파일을 검색한다.
   - -mtime -10 이면 마지막 수정일이 10일 미만인 파일을 검색한다.

정답 find /etc/apache/conf -mtime -10

0167. ○△× 17.2회.산기

다음 명령은 최근 10일 동안 새롭게 생성된 파일을 찾아서 /tmp/algisa.out에 저장하는 명령어이다. 빈칸( )에 적절한 명령어를 작성하시오.

보기

find / -(A) -(B) -print -xdev 〉 /tmp/algisa.out

정답 및 해설

정답 (A) mtime (B) 10

0168. ○△×

시스템 보안에 있어서 SUID(setuid)와 SGID(setgid)는 잠재적인 보안 위험 요소이기 때문에 철저하게 감시되어야 한다. 시스템 전체에서 SUID와 SGID가 설정된 파일을 찾기 위한 방법을 기술하시오.

보기

find 유틸리티를 이용하여 검색하시오.
(A) 전체 디렉터리에서 정규(regular) 파일 중 SUID가 설정된 파일을 모두 찾아내시오.
(B) 전체 디렉터리에서 정규(regular) 파일 중 SGID가 설정된 파일을 모두 찾아내시오.

정답 및 해설

find 명령어의 옵션 중 접근권한/퍼미션(perm) 관련 옵션은 다음과 같다.

1) -perm [-]mode : -가 없으면 정확히 mode 권한과 일치하는 파일, -가 있으면 mode 권한을 포함하는 파일을 검색한다.
   - '-perm 4000'이면 SUID만 설정된 파일 검색하고, '-perm -4000'이면 SUID를 포함하는 파일을 검색
   - '-perm 2000'이면 SGID만 설정된 파일 검색하고, '-perm -2000'이면 SGID를 포함하는 파일을 검색

정답 (A) find / -type f -perm -4000 (B) find / -type f -perm -2000

0169. ○△× 17.1회.산기

다음은 리눅스 시스템에서 사용하는 명령어를 보여주고 있다. 각 명령이 의미하는 바를 쓰시오.

보기

1) find / -ctime -7 -print 〉 ctime7.out
2) find / -user root -perm -4000 -print
3) find / -perm 1777 -print
4) find /dev -type f -print
5) find / -nouser -print

정답 및 해설

1) 최상위 루트 디렉터리(/) 이하 파일 중 파일 속성이 마지막으로 변경된 지(ctime) 7일 이내의 파일을 검색하여 ctime7.out 파일로 출력한다.
2) 최상위 루트 디렉터리(/) 이하 파일 중 소유자가 root(-user root)이고 SUID(setuid)가 설정된(-perm -4000) 파일을 검색하여 출력한다.
3) 최상위 루트 디렉터리(/) 이하 파일 중 sticky bit와 모든 사용자에 읽기(r), 쓰기(w), 실행(x)이 설정된 파일(-perm 1777)을 검색하여 출력한다.
4) /dev 디렉터리 이하 파일 중 일반(정규) 파일(-type f)을 검색하여 출력한다.
5) 최상위 루트 디렉터리(/) 이하 파일 중 소유자가 존재하지 않는 파일(-nouser)을 검색하여 출력한다.

0170. ○△× 17.2회.산기

다음은 침해사고대응(CERT)을 위한 유닉스/리눅스 시스템 보안 체크리스트의 점검 항목 중 일부이다. 각 명령이 어떠한 보안 위협을 제거하기 위한 것인지 기술하시오.

보기

1) find / -type f \(-perm -4000 -o -perm -2000 \) -exec ls -al {} \;
2) find / -type f \(-nouser -o -nogroup \) -print
3) find / -type f -perm -2 -print

정답 및 해설

1) 최상위 루트 디렉터리(/) 이하 모든 일반(정규) 파일에 대해서 SUID(setuid) 또는 SGID(setgid)가 설정된 파일을 검사하는 명령어로 SUID 또는 SGID가 설정된 root 소유자나 소유그룹의 실행파일은 실행 시에 root 권한 상승을 통해 공격에 악용될 수 있는 위협이 존재한다.
2) 최상위 루트 디렉터리(/) 이하 모든 일반(정규) 파일에 대해서 소유자 또는 소유그룹이 존재하지 않는 파일을 검사하는 명령어로 현재 삭제된 사용자 계정(퇴직 등의 사유) 또는 그룹의 소유였거나 관리 소홀로 인해 생성된 파일일 가능성이 높다. 해당 파일의 UID 또는 GID로 특정 사용자 계정의 UID나 특정 그룹의 GID를 악의적으로 변경하면 소유자 또는 소유그룹의 권한으로 해당 파일에 접근할 수 있는 위협이 존재한다.
3) 최상위 루트 디렉터리(/) 이하 모든 일반(정규) 파일에 대해서 소유자나 소유그룹에 속하지 않는 사용자에게(Others) 쓰기 권한이 있는 파일(World writable 파일)을 검사하는 명령어로 중요 파일(시스템 설정 파일 등)에 해당 권한 설정이 되어있으면 비인가자에 의한(권한 없는 사용자에 의한) 악의적인 파일 변경이 발생할 수 있는 위협이 존재한다.

0171. ○△× 23.4회.기사

다음 보기는 유닉스/리눅스 시스템의 보안 체크리스트 점검 항목 중 일부이다. 각 명령이 어떤 보안 조치를 위한 것인지 서술하시오.

보기

1) chmod –s 〈파일명〉
2) find / –user root –type f \(–perm –4000 –o –perm –2000 \) –xdev –exec ls –al {} \;

정답 및 해설

1) 지정한 파일의 SUID(setuid)와 SGID(setgid) 권한을 제거한다.

```
[root@Fedora11 TEST_01]# ls -l sugid.out
-rwsr-sr-x 1 root root 0 2024-01-17 02:44 sugid.out
[root@Fedora11 TEST_01]#
[root@Fedora11 TEST_01]# chmod -s sugid.out
[root@Fedora11 TEST_01]# ls -l sugid.out
-rwxr-xr-x 1 root root 0 2024-01-17 02:44 sugid.out
```

- chmod 명령 시 대상(u,g,o 또는 a)을 지정하지 않으면 a(all) 의미
- 따라서 chmod -s 옵션은 chmod a-s 또는 chmod ug-s 와 동일한 결과를 출력함

2) 최상위 루트 디렉터리(/) 이하 모든 일반(정규) 파일에 대하여 소유자가 root이고 SUID(setuid) 또는 SGID(setgid)가 설정된 파일을 검사하는 명령어로 root 소유의 SUID 또는 SGID가 설정된 실행파일은 실행 시에 root 권한 상승을 통해 공격에 악용될 수 있는 위협이 존재한다. 따라서 주기적 검사를 통해 불필요한 SUID 또는 SGID 권한이 설정된 실행파일의 권한을 제거하는 것이 필요하다.

- –xdev 옵션 : 검색할 디렉터리와 다른 파일시스템은 검색하지 않는 옵션

0172. ○△× 19.2회.산기

다음 보기는 침해사고 분석을 위해 리눅스 시스템에서 수행한 명령어들 일부이다.
각각의 질문에 답하시오.

보기

(A) find / \(–perm –4000 –a –user root \) –print
(B) find /home –name .rhosts –print
(C) find /home \(–type f –a –perm –2 \) –print
(D) find / –type f \(–nouser –o –nogroup \) –print

1) (A) ~ (D) 명령어의 의미를 설명하시오.
2) (A) 명령어 수행 결과 검색된 파일의 보안 위협을 설명하시오.
3) (B) 명령어 수행 결과 검색된 파일의 보안 위협을 설명하시오.

정답 및 해설

1) 각 명령어의 의미는 다음과 같다.
- A : 최상위 루트 디렉터리(/) 이하 모든 파일에 대해서 소유자가 root이고 SUID(setuid)가 설정된 파일을 검색하여 출력한다.
- B : /home 디렉터리 이하 모든 파일에 대해서 파일명이 .rhosts인 파일을 검색하여 출력한다.
- C : /home 디렉터리 이하 모든 일반(정규) 파일에 대해서 소유자나 소유그룹에 속하지 않는 사용자(Others)에게 쓰기 권한이 있는 파일(World writable 파일)을 검색하여 출력한다.
- D : 최상위 루트 디렉터리(/) 이하 모든 일반(정규) 파일에 대해서 소유자나 소유그룹이 존재하지 않는 파일을 검색하여 출력한다.

2) SUID(setuid)가 설정된 root 소유의 실행파일은 실행 시에 root 권한 상승을 통해 공격에 악용될 수 있는 보안 위협이 존재한다.
3) .rhosts 설정을 통해 r계열 서비스(rlogin, rsh 등)를 통한 악의적인 원격 접속 및 셸 실행 등의 공격에 악용될 수 있는 보안 위협이 존재한다.

(C), (D) 명령어 수행 결과 검색된 파일의 보안 위협을 살펴보면 다음과 같다.
- C : 중요 파일(시스템 설정 파일 등)에 해당 권한 설정이 되어있으면 비인가자에 의한(권한 없는 사용자에 의한) 악의적인 파일 변경이 발생할 수 있는 위협이 존재한다.
- D : 소유자나 소유그룹이 존재하지 않는 파일의 UID 또는 GID로 특정 사용자 계정의 UID나 특정 그룹의 GID를 악의적으로 변경하면 소유자 또는 소유그룹의 권한으로 해당 파일에 접근할 수 있는 위협이 존재한다.

0173. ○△× 21.2회.산기

리눅스 시스템 담당자는 서버 취약점 점검을 위해 다음 명령어를 수행하고자 한다. 각각의 질문에 답하시오.

1) 최근 7일 이내에 변경된 파일을 찾는 find 명령어를 작성하시오.
2) 사용자(소유자)가 root이고 SUID(setuid)가 설정된 파일을 찾는 find 명령어를 작성하시오.

정답 및 해설

1) find / –mtime –7
2) find / –user root –perm –4000

0174. ○△× 20.1회.기사

다음 보기는 리눅스 시스템 관리자가 사용하는 중요 디렉터리에 대한 백업용 셸 스크립트 파일과 백업 결과 파일에 관한 내용이다. 각각의 질문에 답하시오.

[백업용 셸 스크립트 파일(backup.sh)]

```
#!/bin/sh
today = $(date +%Y%m%d%H%M%S)
tar -cvzf /data/backup/etc_$today.tgz /etc/*
tar -cvzf /data/backup/home_$today.tgz /home/*
```

[백업 결과 파일 목록]

```
-rw-r--r-- 1 root root  101853308 2021-03-10 13:39 etc_202103101339.tgz
-rw-r--r-- 1 root root       40736 2021-03-10 13:39 home_202103101339.tgz
```

1) 백업 결과 파일의 접근권한을 검토하여 어떤 보안상의 문제가 있는지 설명하시오.
2) 1)의 문제점을 개선하기 위해 백업용 셸 스크립트 파일을 umask 변경 후 백업 파일을 생성하고 umask를 원래대로 재설정하도록 수정하시오.
3) operator 사용자만 백업용 셸 스크립트 파일(/usr/local/bin/backup.sh)을 사용하도록 만드는 명령어를 작성하고 해당 명령어에 대해 간단히 설명하시오.

정답 및 해설

1) 백업 파일이 644 접근권한으로 생성되어 일반 사용자가 생성된 백업 파일에 접근할 수 있는 보안상의 문제점이 있다.
2) 수정한 백업용 셸 스크립트는 다음과 같다.

```
#!/bin/sh
today = $(date +%Y%m%d%H%M%S)
umask 066
tar -cvzf /data/backup/etc_$today.tgz /etc/*
tar -cvzf /data/backup/home_$today.tgz /home/*
umask 022
```

- 백업 파일을 생성하기 전 umask를 066으로 설정하여 생성되는 백업 파일의 접근권한이 600(소유자(root)만 rw 권한을 가짐)이 되도록 함으로써 일반 사용자가 백업 파일에 임의로 접근하는 것을 차단한다.
- 백업 결과 파일 목록을 보면, 생성된 백업 파일의 접근권한이 644이므로 현재 umask는 022 임을 알 수 있다.

3) 백업용 셸 스크립트 파일의 소유자를 operator로 변경한 후 해당 소유자만 접근권한을 가지도록 명령어를 작성한다.
- chown operator /usr/local/bin/backup.sh : 백업용 셸 스크립트 파일의 소유자를 operator로 변경한다.
- chmod 700 /usr/local/bin/backup.sh : 백업용 셸 스크립트 파일의 접근권한을 소유자만 접근할 수 있도록 700으로 변경한다.

0175. ○△×

다음 내용을 보고 아래 문제에 답하시오.

> 보기
> 루트(root) 계정은 리눅스 시스템에서 가장 강력한 권한을 가지고 있는 계정이다. 만약 루트 사용자가 터미널 접속 후 로그아웃하는 것을 잊고 접속한 상태로 방치한다면 비인가자의 악의적인 시스템 접근으로 인해 불필요한 내부정보의 노출 위험이 존재한다.

1) 위와 같은 상황을 방지하기 위해 일정 시간 동안 사용하지 않는 루트 계정이 자동 로그아웃되도록 설정할 수 있는 환경변수는 무엇인가?
2) 이 환경변수를 모든 사용자가 로그인할 때마다 자동으로 적용하고자 한다. 적절한 설정 파일과 설정 방법(권장 시간 600초)을 쓰시오.

정답 및 해설

1) TMOUT 환경변수
- TMOUT 환경변수를 통해 세션 타임아웃 설정을 할 수 있다.
- 권장 설정시간은 600초(10분) 이하로 설정한다.

2) /etc/profile에 아래와 같이 설정한다.

```
# vi /etc/profile
TMOUT = 600
export TMOUT
```

또는

```
# vi /etc/profile
TMOUT = 600; export TMOUT
```

또는

```
# vi /etc/profile
export TMOUT = 600
```

- /etc/profile은 모든 사용자의 로그인 시 적용되는 환경 설정 파일이다.
- 위 설정은 TMOUT 셸 변수에 600초(10분)를 설정한 후 해당 변수를 환경변수(export)로 만들고 있다. export를 통해 환경변수로 만들면 현재 셸뿐만 아니라 자식 셸까지 모두 적용된다.

0176. ○△× 16.2회.기사

리눅스 시스템 관리자(root)는 cron 프로그램을 이용하여 다음과 같은 작업을 수행하려고 한다. 다음 질문에 각각 답하시오.

1) 자신의 crontab 파일(cron 테이블)에 예약된 작업을 확인하기 위한 crontab 명령어를 쓰시오.

2) alsgisa 사용자의 crontab 파일(cron 테이블)을 생성(편집)하기 위한 crontab 명령어를 쓰시오.

3) 자신의 crontab 파일(cron 테이블)에 "/bin/rm -rf" 명령어를 사용하여 /tmp 디렉터리 밑에 있는 모든 파일과 디렉터리를 삭제하는 작업 등록을 위한 명령을 작성하시오. 단, 매주 일요일 오전 03:00에 동작하며 표준 출력은 /dev/null로 보내어 출력되지 않게 하고 표준 에러는 표준 출력으로 재입력하도록 작성하시오.

정답 및 해설

crontab 명령을 사용하여 개별 사용자별 crontab 파일(cron 테이블)을 조작하기 위한 명령어 형식은 다음과 같다.

- 리눅스 시스템 : 계정명을 명시하지 않으면 현재 로그인한 계정을 의미
  - crontab 파일 출력 : crontab -u 계정명 -l(영문 소문자 L)
  - crontab 파일 편집 : crontab -u 계정명 -e (해당 계정의 crontab 파일이 없으면 생성함)
  - crontab 파일 삭제 : crontab -u 계정명 -r (해당 계정의 crontab 파일을 삭제함)
- 유닉스(Solaris) 시스템 : 계정명을 명시하지 않으면 현재 로그인한 계정을 의미
  - crontab 파일 출력 : crontab -l(영문 소문자 L) 계정명
  - crontab 파일 편집 : crontab -e 계정명 (해당 계정의 crontab 파일이 없으면 생성함)
  - crontab 파일 삭제 : crontab -r 계정명 (해당 계정의 crontab 파일을 삭제함)

1) crontab -l(영문 소문자 L)

- 'crontab -l' 명령을 통해 root 사용자의 crontab 파일에는 작업이 등록되어 있고 algisa 사용자의 crontab 파일은 없는 것을 볼 수 있다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)
[root@Fedora11 ~]# crontab -l
0 3 * * 0 /bin/rm -rf /tmp/* >/dev/null 2>&1
[root@Fedora11 ~]#
[root@Fedora11 ~]# su - algisa
[algisa@Fedora11 ~]$ id
uid=519(algisa) gid=508(channel) groups=10(wheel),508(channel),509(sso)
[algisa@Fedora11 ~]$ crontab -l
no crontab for algisa
```

(2) crontab -u algisa -e

- 관리자는 'crontab -u algisa -e' 명령을 통해 algisa 사용자의 crontab 파일을 편집(생성)할 수 있다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)
[root@Fedora11 ~]# crontab -u algisa -e
```

- 관리자는 algisa 사용자가 요구한 정기적인 작업을 등록한다.

```
File Edit View Terminal Help
0 1 * * * /home/algisa/batch.sh
```

- 관리자는 'crontab -u algisa -l' 명령을 통해 algisa 사용자의 crontab 파일에 등록된 작업을 확인할 수 있다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# crontab -u algisa -l
0 1 * * * /home/algisa/batch.sh
```

(3) 0 3 * * 0 /bin/rm -rf /tmp/* >/dev/null 2>&1

0177. ○△× 16.1회.산기

알기사 사이트 관리자는 원격 로그 서버를 구축하여 관리 대상 장비의 syslog를 로컬 및 원격 로그 서버에 모두 남기려고 한다. 아래 보기를 참조하여 관리 대상 장비 및 원격 로그 서버에 설정할 것은 무엇인지 기술하시오.

[관리 대상 장비 - /etc/syslog.conf 내용 일부]

authpriv.* /var/log/secure

(A)

A : 원격 로그 서버(IP : 192.168.133.20)로 인증 관련 로그를 전송하도록 설정

[원격 로그 서버 - 방화벽(iptables) 설정]

#iptables -A INPUT -p (B) --dport (C) -j ACCEPT

B, C : 원격 로그 서버에 관리 대상 장비의 로그를 전송받을 수 있도록 방화벽(iptables) 설정

정답 및 해설

1) syslog.conf 설정 형식

facility.priority; facility.priority; • • •	action(logfile-location)
A.B A.B	C

- facility(A) : 로그를 남길 요소/서비스(예: auth/authpriv, cron, kernel 등), *는 모든 요소/서비스를 의미
- priority(B) : 로그 수준으로 지정한 수준 이상의 상황이 발생했을 때 로그를 남긴다.
- action(C) : 로그 위치를 지정하는 필드로 로그 파일명을 지정하거나 콘솔 또는 원격 로그 서버를 지정할 수 있다. 원격 로그 서버를 지정할 경우에는 '@원격 로그 서버 IP' 형식으로 지정한다.
- 예) *.* @192.168.197.133 : 모든 요소/서비스의 모든 로그 수준에 대해 192.168.197.133 원격 로그 서버에 로그를 전달한다.

2) syslogd 데몬 프로세스를 원격 로그 서버로 설정 시 514/udp(syslog 기본 포트)를 사용한다.

```
File Edit View Terminal Help
[root@Fedora11 ~]# cat /etc/services | grep syslog
syslog          514/udp
```

```
rsyslog.conf
10 #$ModLoad immark.so # provides --MARK-- message capability
11
12 # Provides UDP syslog reception
13 $ModLoad imudp.so
14 $UDPServerRun 514
15
```

(A) authpriv.* @192.168.133.20

(B) udp

(C) 514

0178. ○△× 15.1회.산기 17.2회.산기

다음은 TCP Wrapper를 이용하여 접근 제한을 설정한 것이다. 빈칸( )에 알맞은 내용을 기술하시오.

hosts.deny	hosts.allow	설명
ALL:ALL	ALL : 192.168.10.1	192.168.10.1 IP 주소에 대해 모든 서비스가 가능하다.
ALL:ALL	in.telnetd : 192.168.20.1 in.ftpd : 192.168.30.1	(A)
ALL:ALL	(B)	192.168.1로 시작하는 IP 주소에 대해 ftp 서비스가 가능하다.
ALL:ALL	(C)	www.abc.com을 제외한 모든 .com 도메인의 호스트에 대해 telnet 서비스가 가능하다.
ALL:ALL	ALL EXCEPT in.telnetd : ALL	(D)

정답 및 해설

(A) : 192.168.20.1 IP 주소에 대해 telnet 서비스를 허용하고 192.168.30.1 IP 주소에 대해 ftp 서비스를 허용한다.
(B) : in.ftpd : 192.168.1. (마지막 '.'이 반드시 포함되어야 한다)
(C) : in.telnetd : .com EXCEPT www.abc.com
(D) : 모든 호스트에 대해서 telnet을 제외한 모든 서비스를 허용한다.

0179. ○△× 16.2회.산기

리눅스 서버에서 SSH 원격 접근을 TCP Wrapper를 이용하여 아래와 같이 제한하려고 한다. 이를 위해 /etc/hosts.allow 파일과 /etc/hosts.deny 파일에 추가할 내용을 기술하시오.

(SSH 이외의 서비스에는 영향이 없어야 하며 SSH 데몬은 sshd 이다)

1) 허용할 IP 주소 : 192.168.159.133, 10.10.10.XXX

2) 허용할 IP 이외의 모든 IP 주소에 대해서는 SSH 접속 불가

정답 및 해설

1) /etc/hosts.allow 설정
- sshd : 192.168.159.133, 10.10.10.0/255.255.255.0

2) /etc/hosts.deny 설정
- sshd : ALL (ALL:ALL로 설정할 경우 모든 서비스를 차단하기 때문에 sshd 서비스에 대해서만 접근 차단을 해야 한다)

0180. ○△× 22.1회.산기

리눅스 서버 원격 접속 시 보안상의 이유로 SSH 서비스를 주로 이용하지만 '계정정보 유출', '쉬운 패스워드 사용' 등의 사유로 여전히 취약점이 존재한다. 이를 해결하기 위해 TCP Wrapper를 이용한 SSH 원격 접속에 대한 적절한 접근제어를 설정할 필요가 있다. 다음 요구 조건을 만족하는 TCP Wrapper 설정을 기술하시오.

(SSH 이외의 서비스에는 영향이 없어야 하며 SSH 데몬은 sshd 이다)

1) 허용할 IP 주소 : 123.123.123.123, 124.124.124.XXX(0-255)

2) 허용할 IP 이외의 모든 IP 주소에 대해서는 SSH 접속 불가

정답 및 해설

1) /etc/hosts.allow 설정
- sshd : 123.123.123.123, 124.124.124.0/255.255.255.0

2) /etc/hosts.deny 설정
- sshd : ALL

0181. ○△× 14.1회.산기 17.2회.산기

FTP 서버로 사용하고 있는 리눅스/유닉스 시스템에서 FTP 서비스를 더 이상 사용하지 않고 다른 용도로 사용하려고 한다.

1) 현재 inetd로 제공되고 있는 FTP 서비스를 중지시키고, 재부팅 시에도 더 이상 FTP 서비스가 사용되지 않도록 시스템을 설정하는 방법을 설명하시오.

2) Telnet 서비스에 대해 TCP Wrapper를 통한 접근 제어를 하고자 할 때 inetd.conf 파일을 어떻게 설정해야 하는지 설명하시오.

정답 및 해설

1) inetd 설정 파일인 inetd.conf 파일에 FTP 서비스 부분을 주석 처리(#)한 후 inetd 데몬을 재기동시킨다.

2) inetd 설정 파일인 inetd.conf 파일에서 Telnet 서비스 항목의 실행경로 부분을 in.telnetd에서 tcpd로 수정하게 되면 Telnet 서비스 접속 시 TCP Wrapper의 접근제어를 받게 된다.

구분	서비스	소켓타입	프로토콜	플래그	사용자	실행경로	실행인수
사용 전	Telnet	stream	TCP	nowait	root	/usr/sbin/in.telnetd	in.telnetd
사용 후	Telnet	stream	TCP	nowait	root	/usr/sbin/tcpd	in.telnetd

- TCP Wrapper를 사용하기 전과 후의 Telnet 서비스에 대한 /etc/inetd.conf 설정

0182. ○△×

TCP Wrapper를 통한 접근 제어 설정을 위해 아래 조건에 명시된 순서대로 /etc/hosts.deny 파일과 /etc/hosts.allow 파일을 설정하고자 한다. 빈칸( ) 안에 알맞은 내용을 기술하시오.

보기

/etc/hosts.deny 파일 설정	/etc/hosts.allow 파일 설정
(①) : (②)	(③) : 192.168.1.10 vsftpd : (④) sendmail : ALL (⑤) hacker.co.kr (⑥) : localhost

■ 조건(대소문자를 구분하여 작성하시오)
- 모든 서비스에 대한 모든 클라이언트의 접속을 차단한다.
- in.telnetd 서비스는 192.168.1.10 호스트만 허용하고 vsftpd 서비스는 192.168.1.20 호스트만 허용한다.
- sendmail 서비스는 hacker.co.kr 도메인의 호스트를 제외한 모든 호스트의 접근을 허용한다.
- 로컬 호스트(localhost)는 모든 서비스에 대한 접근을 허용한다.

정답 및 해설

hosts.allow 및 hosts.deny 설정 예는 다음과 같다.

hosts.deny	hosts.allow	설명
ALL : ALL	ALL : 192.168.1.1	192.168.1.1번 IP 주소에 대해 모든 서비스가 이용 가능하다.
ALL : ALL	in.telnetd : 192.168.1.1 in.ftpd : 192.168.1.1, 192.168.1.2	192.168.1.1번 IP 주소에 대해 Telnet과 FTP 서비스가 가능하고, 192.168.1.2번 IP 주소에 대해 FTP 서비스가 가능하다. 그 외의 호스트는 어떤 서비스도 받을 수 없다.
ALL : ALL	in.telnetd : .algisa.co.kr	algisa.co.kr 도메인에 속한 모든 호스트는 Telnet 서비스가 가능하다.
ALL : ALL	ALL : 192.168.1.0/255.255.255.0	192.168.1.0(~192.168.1.255) 네트워크에 속한 모든 호스트는 모든 서비스가 가능하다.
ALL : ALL	in.telnetd : 192.168.1.	192.168.1로 시작하는 IP 주소를 갖는 모든 호스트는 Telnet 서비스가 가능하다.
ALL : ALL	ALL : LOCAL	같은 네트워크에 있는 모든 호스트에 대해 모든 서비스가 가능하다.
ALL : ALL	ALL EXCEPT in.telnetd : ALL	모든 호스트에 대해 Telnet 서비스를 제외한 모든 서비스가 가능하다.
ALL : ALL	in.telnetd : .algisa.com EXCEPT www.algisa.com	www.algisa.com를 제외한 algisa.com 도메인의 모든 호스트에 대해 Telnet 서비스가 가능하다.

정답 ① ALL ② ALL ③ in.telnetd ④ 192.168.1.20 ⑤ EXCEPT ⑥ ALL

0183. ○△×

다음은 xinetd 슈퍼데몬의 telnet 서비스 설정 내용이다. 보기의 조건을 만족하도록 빈칸( )을 채우시오.

보기

```
service telnet
{
  ( ① )        = no
  flags        = REUSE
  socket_type  = stream
  wait         = no
  user         = root
  server       = /usr/sbin/in.telnetd
  log_on_failure  += USERID
  ( ② )        = 192.168.10.0/24
  ( ③ )        = 192.168.10.22
  access_times   = ( ④ )
  ( ⑤ )        = 50 10
  ( ⑥ )        = 100
  per_source   = 10
}
```

■ 조건
- telnet 서비스를 실행한다.
- telnet 서비스에 대해 192.168.10.0/24 IP 대역의 접속만 허용하되 192.168.10.22의 접속은 허용하지 않는다.
- telnet 서비스 허용 시간은 오전 9시부터 오후 6시까지이다.
- 최대 동시 접속 수는 100개로 제한하고 초당 연결개수는 50개로 제한하되 초과 시 10초간 연결을 제한한다.
- 출발지 IP를 기준으로 최대 서비스 연결개수를 10개로 제한한다.

정답 및 해설

xinetd 서비스별 설정 파일의 주요 항목을 살펴보면 다음과 같다.

- disable : 서비스 실행 여부를 설정한다. yes : 실행 안 함, no : 실행함
- only_from : 접근을 허용할 특정 IP 주소 또는 IP 주소 대역을 설정한다.
  (예) only_from = 192.168.56.20 192.168.56.30 : 공백(space)을 구분자로 허용할 IP를 명시
  (예) only_from = 192.168.56.0/24 : IP 주소 대역은 CIDR 표기 사용
- no_access : only_from과 반대로 접근을 차단할 특정 IP 주소 또는 IP 주소 대역을 설정한다.
  (예) 설정 방법은 only_from과 동일
- access_times : 접근을 허용할 시간(24시간 기준) 범위를 설정한다.
  (예) access_times 09:00-12:00 13:00-18:00 : 공백(space)을 구분자로 허용할 시간 범위를 나열
- cps(connection per second) : 초당 연결개수를 제한하기 위해 '초당 최대 연결개수를 설정'한다. 첫 번째 인수는 초당 연결개수를 의미하고 두 번째 인수는 초당 최대 연결개수 초과 시 연결을 제한하는 시간(초 단위)을 의미한다.
  (예) cps = 50 10 : 초당 연결개수를 50개로 제한하고 초과 연결요청 시 10초간 연결을 제한한 후 다시 서비스를 개시한다.
- instances : 동시에 서비스할 수 있는 서버(서비스 프로세스) 개수를 제한하기 위해 '최대 서버(서비스 프로세스) 개수를 설정'한다.
- per_source : 출발지 IP를 기준으로 서비스 연결개수를 제한하기 위한 '출발지 IP별 최대 연결개수를 설정'한다.

정답 ① disable ② only_from ③ no_access ④ 09:00-18:00 ⑤ cps ⑥ instances

0184. ○ △ × 23.4회.기사

다음 보기는 xinetd 슈퍼데몬의 telnet 서비스 설정 내용 중 일부이다. 각각의 질문에 답하시오.

보기

```
service telnet
{
  disable    = no
  ~~~
  (   A   ) = 192.168.56.0/24
  (   B   ) = 192.168.56.100
  access_times   = (   C   )
  (   D   ) = 10
  ~~~
}
```

1) (A)에 지정한 IP의 접속을 허용하는 지시자를 쓰시오.
2) (B)에 지정한 IP의 접속을 차단하는 지시자를 쓰시오.
3) (C)에 09시부터 18시까지 접속을 허용하도록 설정하시오.
4) (D)에 최대 접속자 수를 설정하는 지시자를 쓰시오.

정답 및 해설

1) only_from
2) no_access
3) 09:00-18:00
4) instances
   - (참고) instances 지시자의 경우 '최대 서버 개수 설정', '최대 서비스 개수 설정', '최대 접속자(또는 접속) 수' 등으로 표현될 수 있습니다.

0185. ○ △ × 17.1회.기사

xinetd 데몬은 기존의 inetd 데몬이 가지고 있는 비효율적인 리소스 관리와 보안성 문제를 극복하기 위해 등장한 슈퍼데몬으로 서비스별 다양한 접근제어를 위한 설정 옵션을 가지고 있다. 다음은 xinetd 슈퍼데몬의 telnet 서비스 설정 내용 중 일부이다. A, B, C 각 설정의 의미를 기술하시오.

보기

```
service telnet
{
  disable     = no
  flags       = REUSE
  socket_type = stream
  wait        = no
  user        = root
  server      = /usr/sbin/in.telnetd
  log_on_failure  += USERID
  ( A ) cps = 20 5
  ( B ) instances   = 50
  ( C ) per_source  = 10
}
```

정답 및 해설

(A) cps = 20 5 : 초당 최대 연결개수를 20개로 제한하고 초과 연결요청 시 5초간 연결을 제한한 후 다시 서비스를 개시한다.
(B) instances = 50 : 동시에 서비스할 수 있는 서버(서비스 프로세스)의 최대 개수를 50개로 제한한다.
(C) per_source = 10 : 출발지 IP별로 서비스 최대 연결개수를 10개로 제한한다.

0186. ○ △ × 22.2회.산기

리눅스 시스템에서 다음 보안 조치를 위한 명령어 및 설정을 쓰시오.

1) SSH Login 세션 타임아웃을 10분으로 하여 모든 사용자에게 적용되도록 /etc/profile에 설정한다.

2) 사용자 계정 인증 관련 pam 모듈을 이용하여 계정 잠금 임계값을 설정하고자 한다. 5회 입력 실패 시 패스워드를 잠그고, 자동 계정 잠금 해제 시간을 120초로 설정하고, root 계정은 패스워드 잠금 설정을 적용하지 않는다.

```
#cat /etc/pam.d/system-auth
auth required /lib/security/pam_tally.so ( A ) ( B ) ( C )
```

3) xinetd의 telnet 서비스를 비활성화하도록 설정한다.

```
service telnet
{
  (                    )
  flags       = REUSE
  socket_type = stream
  wait        = no
  user        = root
  server      = /usr/sbin/in.telnetd
  ~~(이하 생략)~~
}
```

정답 및 해설

1) export TMOUT=600 또는 TMOUT=600; export TMOUT

2) A : deny=5, B : unlock_time=120, C : no_magic_root

3) disable = yes

0187. ○ △ × 21.2회.산기

다음은 리눅스 시스템에서 루트(root) 계정의 원격 호스트 접속 차단을 위한 보안 설정에 관한 내용이다. 각각의 질문에 답하시오.

1) Telnet 서비스를 통해 원격 호스트에 루트(root) 계정으로 직접 접근하는 것을 차단하는 설정을 쓰시오.(/etc/pam.d/login 설정 파일에 'auth required /lib/security/pam_securetty.so'가 설정되어 있음)

2) 1)을 설정해도 SSH 서비스를 통한 접근은 차단할 수 없다. SSH 서비스를 통해 원격 호스트에 root 계정으로 직접 접근하는 것을 차단하는 설정을 쓰시오.

3) 1) 및 2)를 설정해도 일반 사용자가 원격 접속을 한 이후에 su 명령을 통해 root 셸(Shell)을 실행할 수 있다. root 셸로 전환하는 것을 봉쇄하고 루트 권한이 필요한 명령어에 대해서는 sudo 명령을 사용하도록 설정하는 방법을 쓰시오.

정답 및 해설

1) securetty 파일(/etc/securetty)에 가상 터미널(pts/번호) 설정을 모두 제거하거나 주석 처리한다.

```
*securetty
22 tty10
23 tty11
24 #pts/0
25 #pts/1
26
```

- pts(pseudo-terminal, 가상터미널) : Telnet, 터미널 등을 통해 접속하는 가상터미널을 의미한다.

2) SSH 데몬(sshd) 설정 파일인 sshd_config 파일의 PermitRootLogin 옵션을 no로 설정한다.

```
sshd_config
40
41 #LoginGraceTime 2m
42 PermitRootLogin no
43 #StrictModes yes
44 #MaxAuthTries 6
```

3) pam_wheel.so PAM 모듈을 이용하여 wheel 그룹에 su를 허용할 계정 이외의 일반 사용자 계정을 제거한 후 sudo 명령 설정 파일인 sudoers 파일에 sudo 명령을 허용할 일반 사용자 계정과 실행을 허용할 명령어를 설정한다.

```
*sudoers
10 algisa   ALL=(ALL)   /was/batch/log_batch.sh
11
```

- 위 예를 살펴보면 algisa 계정은 sudo 명령을 통해 모든 호스트에서 root 권한(모든 계정 권한)으로 /was/batch/log_batch.sh 명령을 실행할 수 있다.

algisa	ALL=(ALL)	/was/batch/log_batch.sh
▪ 계정명 : sudo 명령을 실행할 계정명	▪ 호스트명 : sudo 명령을 실행할 호스트명 또는 IP(ALL은 모든 호스트를 의미) ▪ 실행 권한 계정명 : 명령어 실행 시 가질 권한의 계정명(ALL : root를 포함한 모든 권한)	▪ 명령어: 실행을 허용할 명령어(ALL : 모든 명령어 허용)

0188. ○△× 25.2회.산기

기업 내부에 있는 리눅스 시스템 보안 점검을 다음과 같이 하고자 한다. 각 점검에 필요한 명령 또는 점검 과정을 쓰시오.(단, 파일이나 디렉터리를 명시할 경우 전체 경로 명시)

1) telnet을 통한 root 계정 원격 접속 제한

2) 계정 잠금 임계값을 5로 설정

3) shadow 파일의 소유자 및 접근권한 확인

4) iptables를 이용하여 SSH 접근 차단 설정

정답 및 해설

1) login PAM 서비스 설정 파일(/etc/pam.d/login)에 pam_securetty.so 모듈이 설정되어 있고 /etc/securetty 설정 파일에 pts 관련 설정이 존재하지 않으면(또는 주석 처리) telnet을 통한 root 계정 원격 접속을 제한할 수 있다.

```
# cat /etc/pam.d/login
auth required /lib/security/pam_securetty.so
# cat /etc/securetty
(pts 관련 설정이 존재하지 않거나 주석 처리됨)
```

2) system-auth PAM 서비스 설정 파일(/etc/pam.d/system-auth)에 pam_tally.so(또는 pam_tally2.so) 모듈이 설정되어 있고 해당 모듈의 deny 옵션이 5로 설정되어 있으면 5회 이상 비밀번호 입력 실패 시 계정을 잠글 수 있다.

```
# cat /etc/pam.d/system-auth
auth required /lib/security/pam_tally.so deny=5 ~(생략)~
```

3) ls -l /etc/shadow

4) iptables -A INPUT -p tcp --dport 22 -j DROP

0189. ○△× 15.2회.산기

리눅스 시스템에서 기본 로그파일을 사용하여 아래의 각 작업을 수행하기 위한 명령을 정확한 인수와 함께 제시하시오.

1) algisa라는 ID를 가진 사용자의 최근 로그인 기록 추적

2) 현재로부터 5일 이내에 접근한 로그인 기록 추적

3) wtmp 파일에 저장된 정보 중 시스템 재부팅 기록 추적

4) btmp 파일에 저장된 로그인에 실패한 기록 추적

정답 및 해설

1) lastlog -u algisa
- 가장 최근에(마지막으로) 성공한 로그인 기록을 담고 있는 로그파일이 lastlog 이고, 이를 확인하기 위한 명령어가 'lastlog' 명령어이다.
- '-u 계정명' 옵션을 통해 특정 계정의 최근 접속 기록을 확인할 수 있다.

2) lastlog -t 5
- '-t 계정명' 옵션을 통해 지정한 일수 이내의 접속 기록을 확인할 수 있다.

3) last reboot
- 사용자의 성공한 로그인/로그아웃 정보, 시스템의 Boot/Shutdown 정보에 대한 히스토리를 담고 있는 로그파일이 wtmp(x) 이고, 이를 확인하기 위한 명령어가 'last' 명령어이다.
- 'last 계정명'을 통해 특정 계정의 정보를 확인할 수 있으며, reboot 계정(pseudo user) 지정 시 시스템의 Boot/Shutdown 정보를 확인할 수 있다.

4) lastb
- 실패한 로그인 시도에 대한 기록을 담고 있는 로그파일이 btmp 이고, 이를 확인하기 위한 명령어가 'lastb' 명령어이다.
- 'lastb 계정명'을 통해 특정 계정에 대한 로그인 실패 기록을 확인할 수 있다.

0190. ○△× 20.1회.산기

다음 보기는 유닉스 시스템의 sulog 파일 내용의 일부이다. 각 질문에 답하시오.

보기

```
SU07/12  13:00  + pts/2admin-root
SU07/12  14:00  - pts/0kisa-root
SU07/13  01:00  - pts/11  kisa-root
SU07/13  01:01- pts/11  kisa-root
SU07/13  01:02  - pts/11  kisa-root
SU07/13  01:03  - pts/11  kisa-root
```

1) 보기의 로그를 남기는 명령의 명칭을 쓰시오.

2) 로그의 각 항에 있는 +/-의 의미를 쓰시오.

3) 다수의 항에서 보이는 kisa-root의 의미를 쓰시오.

4) (1) 명령을 실행하는 실행파일은 root 소유자 및 소유그룹이다. root 소유자 및 소유그룹 이외에는 해당 파일을 실행하지 못하도록 하는 방법을 쓰시오.

정답 및 해설

sulog 로그파일은 유닉스 시스템에서 su(switch user) 명령 사용 결과를 저장한 파일로 텍스트 형식으로 되어있다. 허용되지 않은 root 계정으로의 su 명령 시도가 발생하는지 관리자의 주기적인 확인이 필요하다.

1) su(switch user) 명령

2) + : su 명령이 성공했음을 의미, - : su 명령이 실패했음을 의미

3) kisa 계정에서 root 계정으로 전환(su)을 시도했음을 의미한다.

4) su 실행파일의 접근권한(permission)에 user(소유자)와 group(소유그룹)에만 실행 권한(x)을 부여하고 others (기타 사용자)에는 실행 권한(x)을 제거한다.

0191. ○△× 18.2회.산기

다음 각 항목에서 요구하는 리눅스 시스템 명령어를 작성하시오.

1) 전체 시스템에서 3일 이내에 생성되거나 내용이 수정된 파일을 모두 출력하시오.

2) 3일 이내에 시스템에 로그인한 사용자를 출력하시오.

3) useradd 명령어를 사용한 사용자 정보와 시간을 출력하시오.

정답 및 해설

1) find / -mtime -3

2) lastlog -t 3

- lastlog 명령을 이용하면 모든 계정의 최근 로그인한 기록을 확인할 수 있다.
- 예) lastlog -u "계정명" : 해당 계정의 최근 로그인한 기록 확인
- 예) lastlog -t "일수" : 해당 일수 이내에 로그인한 기록 확인

3) lastcomm --command useradd(또는 lastcomm useradd 또는 lastcomm | grep '^useradd')

```
root@Fedora11:~                                  root@Fedora11:~
[root@Fedora11 ~]# lastcomm --command useradd
useradd          S     root     pts/2      0.00 secs Sat Feb  2 18:20
[root@Fedora11 ~]#
[root@Fedora11 ~]# lastcomm useradd
useradd          S     root     pts/2      0.00 secs Sat Feb  2 18:20
[root@Fedora11 ~]#
[root@Fedora11 ~]# lastcomm | grep '^useradd'
useradd          S     root     pts/2      0.00 secs Sat Feb  2 18:20
[root@Fedora11 ~]#
```

- lastcomm 명령을 이용하면 로그인한 모든 사용자가 로그아웃할 때까지 실행한 명령어, 플래그, 실행한 계정명, 터미널 타입, 프로세스 시작 시간 등의 기록을 확인할 수 있다.
- 사용법) lastcomm [command-name] [user-name] [terminal-name]
- 예) lastcomm useradd : 명령어나 사용자명 또는 터미널 타입에 useradd가 있으면 모두 출력, 명령어나 사용자명 또는 터미널 타입을 명확히 지정하려면 아래와 같이 사용한다.
- 예) lastcomm --command useradd : 명령어가 useradd이면 모두 출력한다.
- 예) lastcomm --user root : 사용자명이 root이면 모두 출력한다.
- 예) lastcomm --tty tty0 : 터미널 타입이 tty0면 모두 출력한다.
- 예) lastcomm --user root --command useradd : 사용자명이 root이거나 명령어가 useradd이면 모두 출력한다.
- 예) lastcomm --strict-match --user root --command useradd : strict-match 옵션을 사용하면 조건을 모두 만족할 때만 출력한다. 따라서 사용자명이 root이고 명령어가 useradd인 경우만 출력한다.

0192. ○△× 22.4회.산기

다음 보기의 xferlog 정보를 참조하여 각각의 질문에 답하시오.

```
Sat Nov 5 02:19:26  2022  2  192.168.1.132  34567
/home/user/testfile.html  b  T  i  g  algisa  ftp  1  *  i
```

(1) 일시 (2) 전송자 (3) 행위 주체 식별자 (4) 접근 방식 (5) 전송 파일 (6) 성공/실패 유무

정답 및 해설

보기의 로그 각 항목을 살펴보면 다음과 같다.

ⓐ	ⓑ	ⓒ	ⓓ	ⓔ
Sat Nov 5 02:19:26 2022	2	192.168.1.132	34567	/home/user/testfile.html

ⓕ	ⓖ	ⓗ	ⓘ	ⓙ	ⓚ	ⓛ	ⓜ	ⓝ
b	T	i	g	algisa	ftp	1	*	i

ⓐ 전송 날짜 및 시간(일시, current time) : Sat Nov 5 02:19:26 2022
ⓑ 전송 소요 시간(transfer time, 초) : 2초
ⓒ 원격 호스트 주소(전송자, remote host) : 192.168.1.132
ⓓ 전송 파일 크기(file size, byte) : 34567byte
ⓔ 전송 파일명(file name) : testfile.html
ⓕ 전송 파일 유형(transfer type) : 바이너리(b) 전송
- a : ascii(아스키, 텍스트), b : binary(바이너리)

ⓖ 액션 플래그(special action flag) : 파일이 tar로 묶임(T)
- _ : 액션 없음, C : 파일이 압축됨, U : 압축된 파일이 해제됨, T : 파일이 tar로 묶임(아카이브됨)

ⓗ 전송 방향(direction) : 서버로 파일 업로드(i)
- i : incoming(서버로 파일 업로드), o : outgoing(서버에서 파일 다운로드), d : delete(서버 파일 삭제)

ⓘ 접근 방식(access mode) : 게스트 계정으로 접근(g)
- r : real(로컬 시스템 계정으로 접근), a : anonymous(익명 계정으로 접근)
- g : guest(게스트 계정으로 접근), 게스트 계정이란 시스템 계정이 아닌 FTP 접속만을 위해 FTP 서버에서 만든 가상의 계정을 의미한다.

ⓙ 사용자 명(user name) : algisa
ⓚ 서비스 명(service name) : ftp 서비스
ⓛ 인증 방법(authentication method) : RFC 931 인증(1)
- 0 : 없음, 1 : RFC 931 인증

ⓜ 인증된 사용자 ID(authenticated user id) : 인증된 사용자 ID 이용 불가(*)
- 인증 메서드에 의해 반환되는 사용자 ID로 *인 경우 이용이 불가능한 상태를 의미한다.

ⓝ 완료 상태(성공/실패 유무) : 전송 실패(i)
- c : complete(전송 성공), i : incomplete(전송 실패)

(1) 일시 : Sat Nov 5 02:19:26 2022 (2) 전송자 : 192.168.1.132
(3) 행위 주체 식별자 : algisa (4) 접근 방식 : 게스트 사용자(g)
(5) 전송 파일 : testfile.html (6) 성공/실패 유무 : 전송 실패(i)

0193. ○△× 20.2회.산기

보안 관리자는 관리하는 리눅스 서버의 파일 송수신 내역을 확인하고자 한다. 다음 xferlog에 대한 각각의 질문에 답하시오.

```
......
Thu May 17 11:54:41 2020 6 file.test.kr 345678 /home/algisa/test1.mp3 b _ i r kiwi99 ftp 0 * c
Thu May 17 11:54:42 2020 7 file.test.kr 123456 /home/algisa/test2.mp3 b _ i r kiwi99 ftp 0 * c
......
```

1) 밑줄 친 로그 내역을 참조하여 다음 7가지 항목에 관해 설명하시오.
① 원격 호스트 주소, ② 전송된 파일명, ③ 전송에 걸린 시간, ④ 로그인 사용자 ID
⑤ 전송 방향, ⑥ 파일 전송 성공/실패 여부, ⑦ 전송 파일 유형

2) ⑤ ~ ⑦번 항목에 대한 근거를 서술하시오.

정답 및 해설

1) 7가지 항목의 내용은 다음과 같다.
① 원격 호스트 주소 : file.test.kr
② 전송 파일명 : test1.mp3
③ 전송에 걸린 시간 : 6초
④ 로그인 사용자 ID : kiwi99
⑤ 전송 방향 : 서버로 파일 업로드(i)
⑥ 파일 전송 성공/실패 여부 : 전송 성공(c)
⑦ 전송 파일 유형 : 바이너리 파일(b)

2) ⑤ - ⑦번 항목에 대한 근거는 다음과 같다.
⑤ 전송 방향 항목에 파일을 서버로 올릴 때 i(incoming), 서버에서 내릴 때 o(outgoing)로 표시한다.
⑥ 파일 전송 성공/실패 항목에 전송 성공 시에 c(complete), 전송 실패 시에 i(incomplete)로 표시한다.
⑦ 전송 파일 유형 항목에 바이너리 파일이면 b(binary), 텍스트 파일이면 a(ascii)로 표시한다.

0194. ○ △ × 19.2회.산기

침해사고가 발생한 대부분 시스템에는 공격 관련 로그와 함께 침입 후 공격자를 통해 수행한 작업의 흔적들이 로그에 남게 되므로 로그 분석을 통한 사고원인 분석은 매우 중요하다. 리눅스 시스템의 사고원인을 파악하는 과정에서 의심스러운 사용자의 작업 흔적을 확인하기 위해서는 사용자가 입력한 명령어 추적이 필요하다. 다음 질문에 답하시오.

1) 사용자 명령어 추적을 위한 pacct(/var/account/pacct) 로그파일은 기본으로 생성되는 로그파일이 아니다. 이를 활성화하는 명령어를 쓰시오.

2) 아래의 gcc 명령어를 실행한 사용자 결과를 보여주는 명령어를 쓰시오.

```
gcc        algisa   pts/2    0.00 secs Tue Dec 24 16:10
gcc        algisa   pts/2    0.00 secs Tue Dec 24 16:10
gcc        algisa   pts/2    0.00 secs Tue Dec 24 16:10
```

3) pacct 로그파일을 logrotate를 이용하여 보관하려고 한다. 설정 파일에 포함된 각 옵션의 의미를 설명하시오.

(A) create 0600 root root
(B) size 100M
(C) compress
(D) rotate 10

정답 및 해설

1) accton /var/account/pacct
2) lastcomm gcc 또는 lastcomm | grep '^gcc' 또는 lastcomm --command gcc
3) logrotate 각 설정의 의미는 다음과 같다.
A : 소유자/소유그룹이 root이고 퍼미션이 0600인 로그파일을 새롭게 생성한다.
B : 로그파일의 크기가 100MB가 되면 순환한다.
C : 로그를 압축하여 저장한다.
D : 순환시킬 로그파일의 개수를 10개로 설정한다.

✓ pacct 로그파일을 활성화하는 명령어 사용 방법은 다음과 같다.

```
root@Fedora11:~
[root@Fedora11 ~]#accton /var/account/pacct
[root@Fedora11 ~]# ps -ef > /dev/null
[root@Fedora11 ~]# ls -al > /dev/null
[root@Fedora11 ~]# lastcomm root
ls                 root     pts/3      0.00 secs Sun Feb  9 19:42
ps           S     root     pts/3      0.00 secs Sun Feb  9 19:42
accton       S     root     pts/3      0.00 secs Sun Feb  9 19:41
[root@Fedora11 ~]#
[root@Fedora11 ~]#accton
```

- 활성화 : accton 명령어의 인자로 pacct 로그파일 경로를 설정하여 실행한다.
- 비활성화 : 인자 없이 accton 명령어를 실행하면 더 이상 로그를 남기지 않는다.

0195. ○ △ × 21.1회.산기

리눅스 시스템 관리자가 logrotate 로그파일 순환 정책을 점검하는 과정에서 아래와 같이 〈기본 설정〉을 〈변경 설정〉으로 수정하였다. 다음 각각의 질문에 답하시오.

〈기본 설정〉	〈변경 설정〉

/var/log/btmp{
missingok
monthly
create 0600 root utmp
rotate 1
}
	/var/log/btmp{
	(1) missingok
	monthly
	(2) create 0640 root utmp
	(3) rotate 6
	(4) dateext
	}

1) btmp 로그파일에 저장되는 정보를 서술하시오.

2) (1) ~ (4) 각 설정의 의미를 서술하시오.

정답 및 해설

1) 실패한 로그인 시도에 대한 기록을 담고 있다.
2) 각 설정의 의미는 다음과 같다.
- (1) missingok : 로그파일이 없어도 오류를 발생시키지 않는다.
- (2) create 0640 root utmp : 순환 시 새롭게 로그파일을 생성하며 파일 퍼미션은 0640, 소유자는 root, 소유그룹은 utmp로 설정한다.
- (3) rotate 6 : 순환 로그파일의 개수를 6개로 설정한다.
- (4) dateext : 로그파일의 확장자로 날짜를 붙여서 저장한다.

0196. ○ △ × 16.2회.기사

다음은 a.out 실행파일의 C 소스코드이다. UID가 500인 사용자가 4775 권한의 root 소유 a.out 파일을 실행할 경우 다음 보기의 빈칸에 적절한 내용을 기술하시오.

setuid.c

```
1 #include <stdio.h>
2 #include <stdlib.h>
3 #include <string.h>
4 #include <unistd.h>
5 #include <sys/types.h>
6
7 int main(int argc, char** argv){
8     int ruid=0;
9     int euid=0;
10    int suid=0;
11
12    getresuid(&ruid, &euid, &suid);
13    printf("[Before setuid(1000)] Real UID:%d\t Effective UID:%d\t Saved UID:%d
  \t \n",ruid,euid,suid);
14    setuid(1000);
15    getresuid(&ruid, &euid, &suid);
16    printf("[After setuid(1000)] Real UID:%d\t Effective UID:%d\t Saved UID:%d
  \t \n",ruid,euid,suid);
17    return 0;
18 }
19
```

```
[kiwi99@Fedora11 C04_Setuid_gid]$ id
uid=500(kiwi99) gid=500(kiwi99) groups=500(kiwi99)
[kiwi99@Fedora11 C04_Setuid_gid]$
[kiwi99@Fedora11 C04_Setuid_gid]$ ls -l a.out
-rwsrwxr-x 1 root root 5321 2017-01-23 22:40 a.out
[kiwi99@Fedora11 C04_Setuid_gid]$
[kiwi99@Fedora11 C04_Setuid_gid]$ ./a.out
```

[실행결과]

[Before setuid(1000)] Real UID : 500 Effective UID : (A) Saved UID : (A)

[After setuid(1000)] Real UID : (B) Effective UID : (C) Saved UID : (C)

정답 및 해설

1) a.out 프로그램은 root 소유의 setuid가 설정되어 있다. 따라서 실행하면 다음과 같이 uid가 설정된다.
   - uid 500(kiwi99) 계정으로 실행하였으므로 'Real UID'는 500으로 설정된다.
   - setuid가 설정되어 있으므로 실행파일 소유자의 UID로 'Effective UID'와 'Saved UID'가 설정된다. 따라서 소유자인 root의 UID인 0로 'Effective UID'와 'Saved UID'가 설정된다.
2) setuid(uid_t uid) 함수는 호출한 프로세스의 'Effective UID'를 변경한다. 단, 호출한 프로세스의 'Effective UID'가 0(root)일 경우 'Real UID'와 'Saved UID'를 모두 변경한다.
   - setuid(1000) 함수 호출 시점에 'Effectiv UID'가 0(root)이므로 'Real UID', 'Effective UID', 'Saved UID'가 모두 1000으로 설정된다.
3) Saved UID(Saved User ID)
   - 'Saved UID'는 프로세스의 권한을 낮게 변경했다가 원래대로 복구할 때 사용되는 UID이다.
   - 프로세스의 권한이 낮게 변경될 때, 변경 전의 'Effective UID'가 'Saved UID'에 저장된다.
   - 이후, 낮은 권한이 원래의 권한으로 복귀될 때 'Saved UID'가 'Effective UID'에 저장된다.

답 (A) 0 (B) 1000 (C) 1000

0197. ○ △ × 14.2회.기사

다음에 예시한 두 코드의 실행 결과는 같다. 그러나 버퍼 오버플로우 공격이 있으면 한 코드는 취약하지만 다른 하나는 안전하다. 안전한 코드가 되도록 빈칸 (A), (B)를 적절히 채우시오.

취약한 코드	안전한 코드

#include 〈stdio.h〉
#include 〈string.h〉
#inlucde 〈ctype.h〉
void main(int argc, char **argv){
char buffer[1024];
if(argc 〉 1){
strcpy(buffer,argv[1]);
}
printf("buffer %s₩n" ,buffer);
}
	#include 〈stdio.h〉
	#include 〈string.h〉
	#include 〈ctype.h〉
	void main(int argc, char **argv){
	char buffer[1024];
	if(argc 〉 1){
	if(_(A)_ 〉= _(B)_) {
	fprintf(stderr, "too long ₩n");
	exit(1);
	}
	strcpy(buffer,argv[1]);
	}
	printf("buffer %s₩n" ,buffer);
	}

정답 및 해설

1) 취약한 코드를 살펴보면 입력값의 크기를 검사하지 않는 strcpy() 함수를 사용하여 외부 입력값(argv[1])을 그대로 버퍼(buffer)에 복사하고 있으므로 스택 버퍼 오버플로우의 취약점이 존재한다. 취약점을 제거하기 위해서는 입력값의 크기를 제한하는 strncpy() 함수를 사용하거나 코딩 시 입력값의 크기를 검사해야 한다.
   - strcpy(char *dst, const char *src) : src 문자열을 dst 버퍼에 저장한다. src 문자열의 길이를 검사하지 않기 때문에 버퍼 오버플로우 공격이 발생할 수 있다.
   - strncpy(char *dst, const char *src, size_t len) : src 문자열의 len 만큼을 dst 버퍼에 저장한다. src 문자열의 길이를 제한할 수 있으므로 버퍼 오버플로우 공격에 안전하다.
2) 안전한 코드를 살펴보면 조건문을 통해 입력값의 크기를 검사하여 입력값이 버퍼(buffer)의 크기와 같거나 크면 프로그램을 종료하도록 하고 있다. 주의할 점은, 버퍼의 크기와 같은 입력 문자열인 경우에도 문자열의 끝을 의미하는 null 문자(0x00)가 포함될 수 없으므로 버퍼의 크기와 같은 문자열도 검사해야 한다.
   - size_t strlen(const char *str) : 문자열(src)의 null 문자를 제외한 바이트 수를 반환한다.
   - argv[] 매개변수 : C 언어에서 main 함수를 통해 전달되는 매개변수는 argv 포인터배열을 통해 받을 수 있다. 배열의 인덱스순으로 argv[0]은 프로그램명, argv[1]은 첫 번째 매개변수가 된다.
   - sizeof(피연산자) : 피연산자의 크기를 반환한다.

답 (A) strlen(argv[1]) (B) sizeof(buffer) 또는 1024